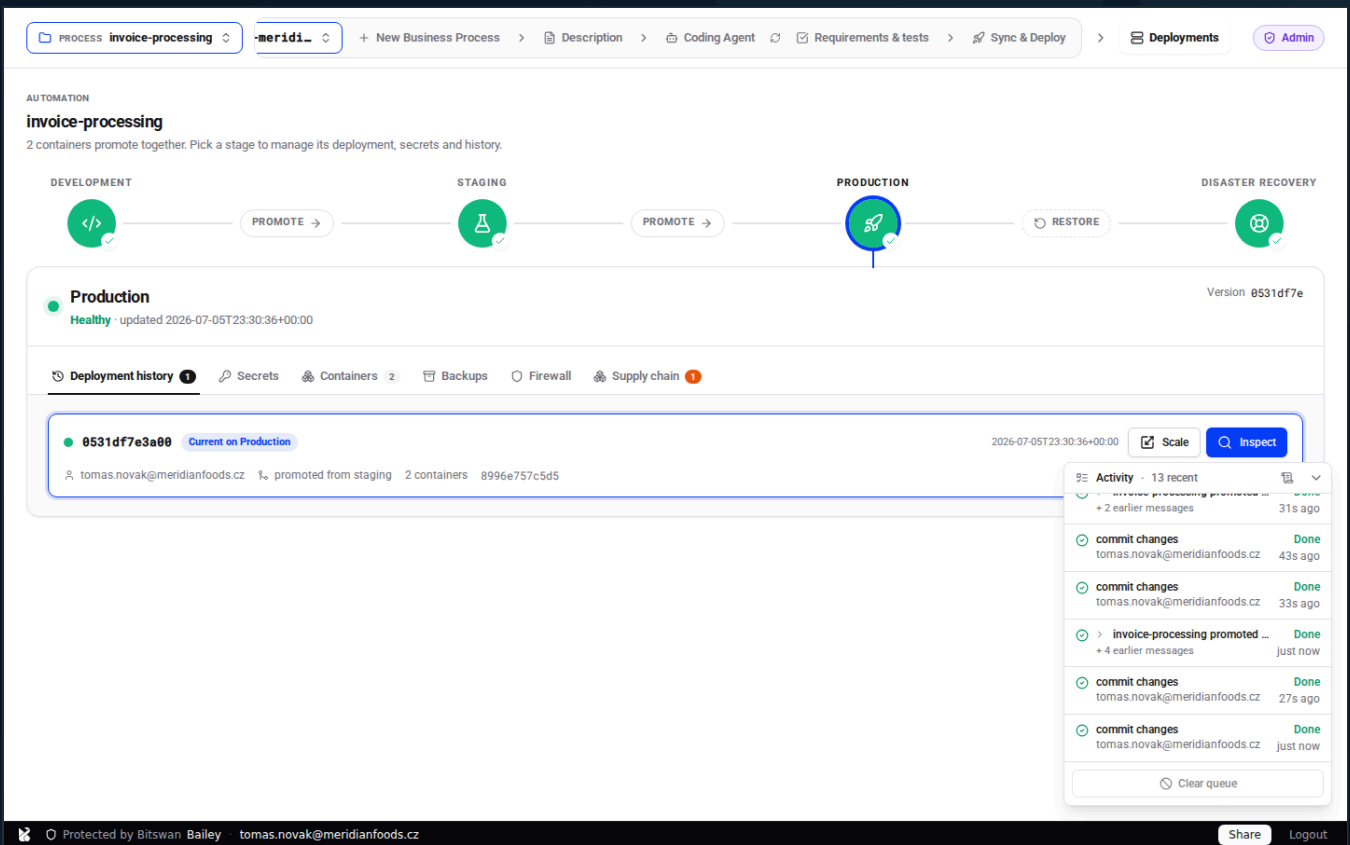


Run it like it matters.

Business processes on infrastructure that defends itself.

Staged deployment. One-click disaster-recovery rehearsals. Supply-chain scanning before anything ships. A GDPR record of processing that writes itself. Access control an auditor will actually like.

Bailey is **best practice**.



The screenshot displays the BitSwan Bailey interface for an automation named 'invoice-processing'. The top navigation bar includes a breadcrumb trail: PROCESS invoice-processing > meridi > + New Business Process > Description > Coding Agent > Requirements & tests > Sync & Deploy > Deployments > Admin. The main content area shows the automation's lifecycle stages: DEVELOPMENT, STAGING, PRODUCTION, and DISASTER RECOVERY. The 'PRODUCTION' stage is currently selected and highlighted. Below the stages, the 'Production' status is shown as 'Healthy' with a timestamp of 'updated 2026-07-05T23:30:36+00:00'. A 'Deployment history' section lists various deployment events, including 'commit changes' and 'invoice-processing promoted'. A right-hand sidebar displays a list of recent activity, including 'commit changes' and 'invoice-processing promoted', with timestamps and user information. The bottom of the interface shows a footer with the text 'Protected by BitSwan Bailey' and the email 'tomas.novak@meridianfoods.cz'.

- Every screenshot in this manual was captured live, walking the real product on 2026-07-05.

You shouldn't have to build the car.

For years, “business-process automation” has meant **sheet-metal products**: all the parts you need to build a car. A pile of screws, brackets and sub-assemblies — with a manual that quietly assumes you'll weld the chassis, wire the loom and certify the brakes yourself. You wanted to move goods; you got a parts catalogue.

The “off-the-shelf” platforms that promised to spare you the assembly were designed **before the agentic-coding era**. Next to what's now possible, they're **toy cars** — fine on a showroom floor, never built for the road you actually drive.

Bailey is a real, fully functional **business-process automation platform** — ready and **compliant** out of the box, not a kit you assemble and certify yourself. Staged deployment, one-click disaster-recovery rehearsals, supply-chain scanning, device-bound access and a self-writing GDPR record are already in the chassis.

So you can think about **where you're driving** — not how to install the engine.

CONTENTS

The Operator's Handbook

·	Why teams put Bitswan in front of what matters	6
---	--	---

THE WALKTHROUGH

CH 01	Claim & device trust — Get in safely	7
CH 02	Workspaces — Draw the boundary	10
CH 03	Server overview & endpoints — See the estate	13
CH 04	Your devices — Manage your hardware	16
CH 05	The workspace & copies — Work in the open	19
CH 06	Business processes — Define the work	22
CH 07	Describe the process — Say what it does	25
CH 08	Coding Agent & requirements — Build it	28
CH 09	Dev, staging & production — Separate the blast radius	32
CH 10	Sync & Deploy — Ship changes	35
CH 11	Blue-green production — Promote with confidence	39
CH 12	Deployment history & inspect — Show your work	43

CH 13	Secrets	— Keep secrets secret	49
CH 14	Containers	— See what's running	52
CH 15	Backups & retention	— Capture the truth	55
CH 16	Rehearse & restore (DR)	— Sleep at night	57
CH 17	Firewall & data processing	— Control the edges	61
CH 18	Supply chain	— Know your ingredients	65
CH 19	People & roles	— Right people, right rights	68
CH 20	Sharing an endpoint	— Let the right people in	71
CH 21	SIEM export & monitoring	— Feed the watchtower	74
CH 22	A teammate's first login	— Deny by default	78
CH 23	Approve the person & trust the device	— You decide who gets in	81
CH 24	Access granted	— In, on a trusted device	85
CH 25	Memory governance & the on-demand pool	— Make a mess safely	88
COMPLIANCE REFERENCE			
REF	Standards → features		93
REF	What Bailey gives you — at a glance		103
REF	ISO/IEC 27001:2022		105
REF	SOC 2 (Trust Services Criteria)		108

REF	DORA (Regulation (EU) 2022/2554)	110
REF	NIS2 (Directive (EU) 2022/2555)	112
REF	GDPR (Regulation (EU) 2016/679)	114

WHY TEAMS PUT BITSWAN IN FRONT OF WHAT MATTERS

01 **Ship without holding your breath**

Promote dev → staging → production across three blue-green slots over two persistent databases. The live slot never blinks; the standby is always one cutover away.

02 **Rehearse the disaster before it happens**

Restore any production backup into an isolated DR slot, verify it by hand, mark it recovery-tested, then swap it live with a single ingress cutover. No data move. No downtime.

03 **Know what's inside before it runs**

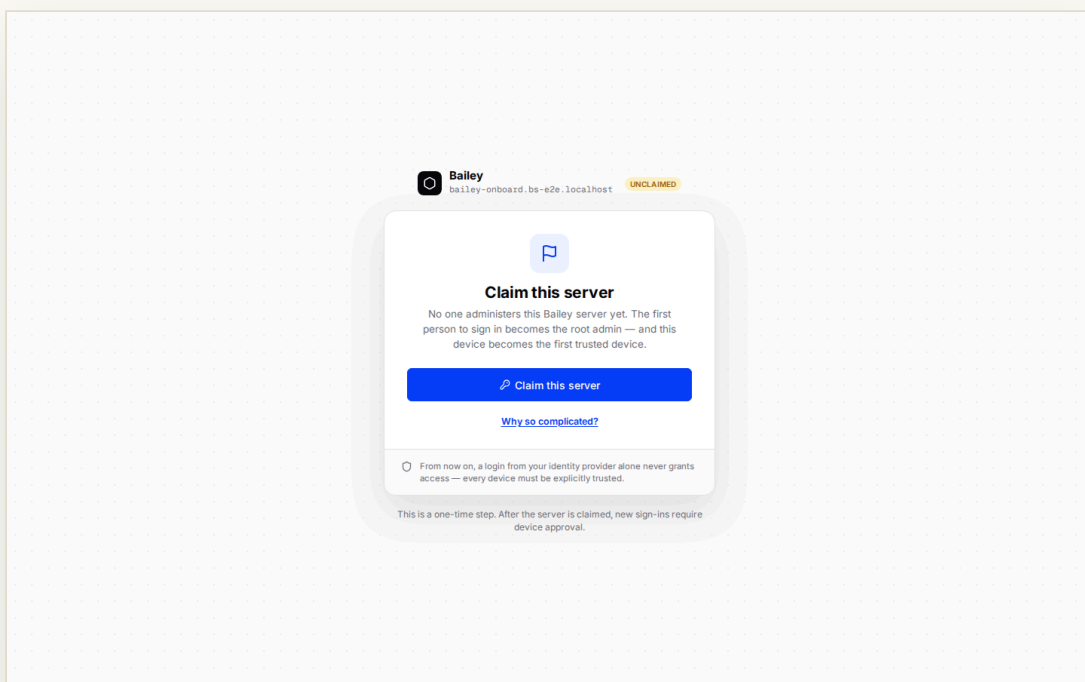
Every image is scanned for CVEs before deploy. Waivers live in your source tree, not buried in config. Auditors get a clean, signed story.

04 **Trust the device, not just the password**

The first operator claims the server; every device after is explicitly approved. Bailey practises defence in depth — your processes stay protected even if a password leaks or your identity provider is compromised.

Claim & device trust

The first operator claims the server and becomes root admin. Their device becomes the first trusted device — and every device after is approved, not assumed.



Bailey onboarding · signed in, about to claim the server

A password that leaks shouldn't be the end of the story. Bailey binds access to **trusted devices**: Tomáš Novák signs in through your identity provider, claims the Meridian Foods server, and the browser he claimed from is enrolled as the first trusted device — its cookie now proves the hardware, not just the credential.

From then on a new device must be **approved by someone who already holds one**: it shows a six-digit code and waits, and a trusted operator links it from *Your devices* → *Link a device*. The gate sits in front of everything — the console and every workspace app run behind it.

HOW TO

- 1 Sign in at the onboarding host.
- 2 Click **Claim this server** — you become root admin and this device is trusted.
- 3 A new device shows a code and waits for approval.
- 4 Approve it from a trusted device, or revoke it from **People & roles**.

WHY IT MATTERS

Bailey practises defence in depth. It is an isolated, self-protecting system using what we call end-to-end authentication — so a stolen password, or even a fully compromised identity-provider / SSO account, does not compromise Bailey or reach the business processes behind it.



Bailey is best practice — what the standards ask of you, and how this does it

NIS2

ART. 21(2)(J)

Multi-factor authentication & secured

access. Device trust is a strong second factor bound to hardware — exactly the “MFA or continuous authentication” the directive expects.

SOC 2

CC6.1

Logical access security.

The gate authenticates and authorizes every request before it reaches a workspace app.

ISO/IEC 27001

A.5.15 / A.8.5

Access control & secure authentication.

Access is granted per identity and per device, and centrally revocable.

DORA

ART. 9(3)

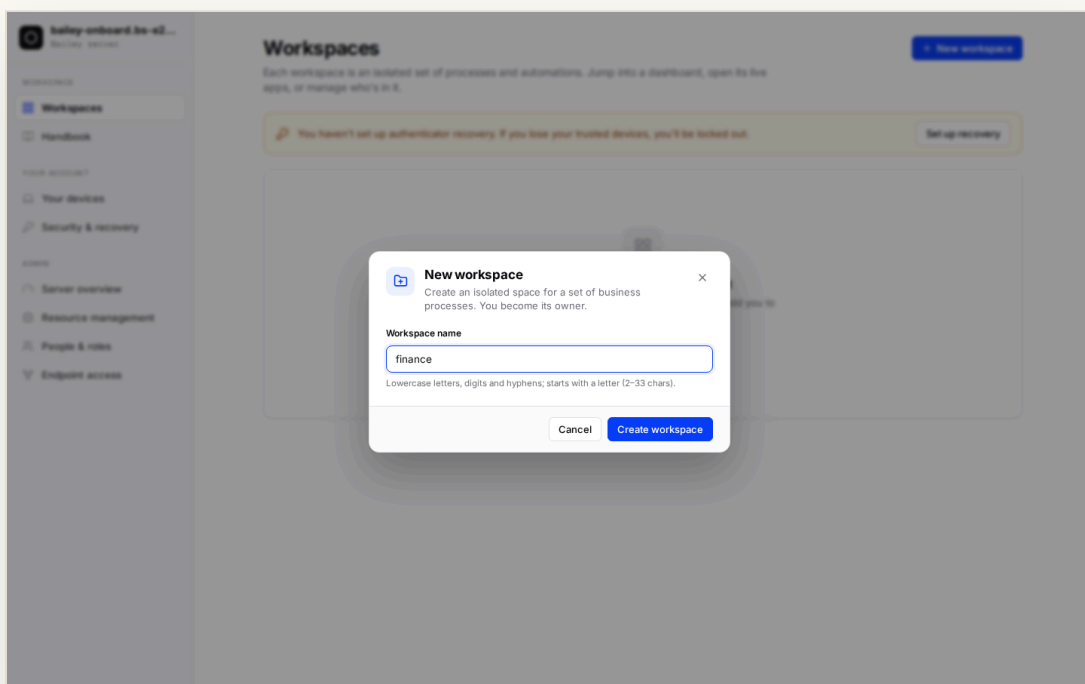
Strong authentication mechanisms.

Protection of ICT systems requires robust access control — the gate provides it uniformly.



Workspaces

A workspace is a thematic access-control boundary — an isolated tenancy, scoped to a body of work and the team that does it. Who can see and do what is decided per workspace.



Server Console · the Workspaces view with the Finance workspace

Workspaces are **thematic, not per-company**. Meridian Foods automates invoice-processing as part of its finance work, so Tomáš creates a **Finance** workspace from the Bailey Server Console and becomes its owner. It is shared only with the people automating finance processes; a separate *Logistics* workspace would be its own tenancy, invisible to them. Creation is a live,

streamed operation — you watch gitops, ingress and the dashboard come up before the workspace appears with an *Open* button.

A workspace is a blast radius for **access**: its own processes, its own data, and its own roster. Only the people granted into it — at the role you give them — can reach its apps. (Promoting code through dev → staging → production happens *inside* a process; that's the stages, not the workspace — see Ch 09.)

HOW TO

- 1 Open **Workspaces** in the console.
- 2 Click **New workspace**, name it (lowercase, hyphenated) — you're the owner.
- 3 Watch it provision; press **Open** to enter its dashboard.
- 4 Invite members at the role they need.



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.3 / A.5.15

Information access restriction & access

control. A workspace scopes who can reach its processes and data; access is granted per workspace.

SOC 2

CC6.3

Role-based access. Membership and roles are assigned per workspace and enforced server-side.

NIS2

ART. 21(2)(I)

Asset management & access control. Every workspace and its endpoints are inventoried and owned.

Server overview & endpoints

Before you build, know what you're running. The console's overview and endpoint pages inventory every workspace, route and protected endpoint on the server.

The screenshot displays the 'Server overview' page in the console. The left sidebar contains navigation links for 'WORKSPACE' (Workspaces, Handbook), 'YOUR ACCOUNT' (Your devices, Security & recovery), and 'ADMIN' (Server overview, Resource management, People & roles, Endpoint access). The main content area is titled 'Server overview' and includes a subtitle: 'bailey-onboard.bs-e2e.localhost — manage workspaces, people, and the devices this server trusts.' Below this are four summary cards: 'WORKSPACES 0', 'PEOPLE 1', 'DEVICES 1', and 'PENDING 0 All clear'. A detailed card for 'bailey-onboard.bs-e2e.localhost' shows it is 'ONLINE', with details for Region, Version (dev), Claimed by (tomas.novak@meridianfoods.cz), Claimed (7/5/2026, 11:19:22 PM), and Uptime (35s). To the right, 'Recent security activity' lists two events: device approval and server claiming. The 'System resources' section shows Memory (17% used), Disk (47% used), and CPU (89% load). At the bottom, 'SIEM forwarding' is shown as 'DISCONNECTED', and a notification bubble states 'Workspace "finance" created'.

Server Console · the server overview

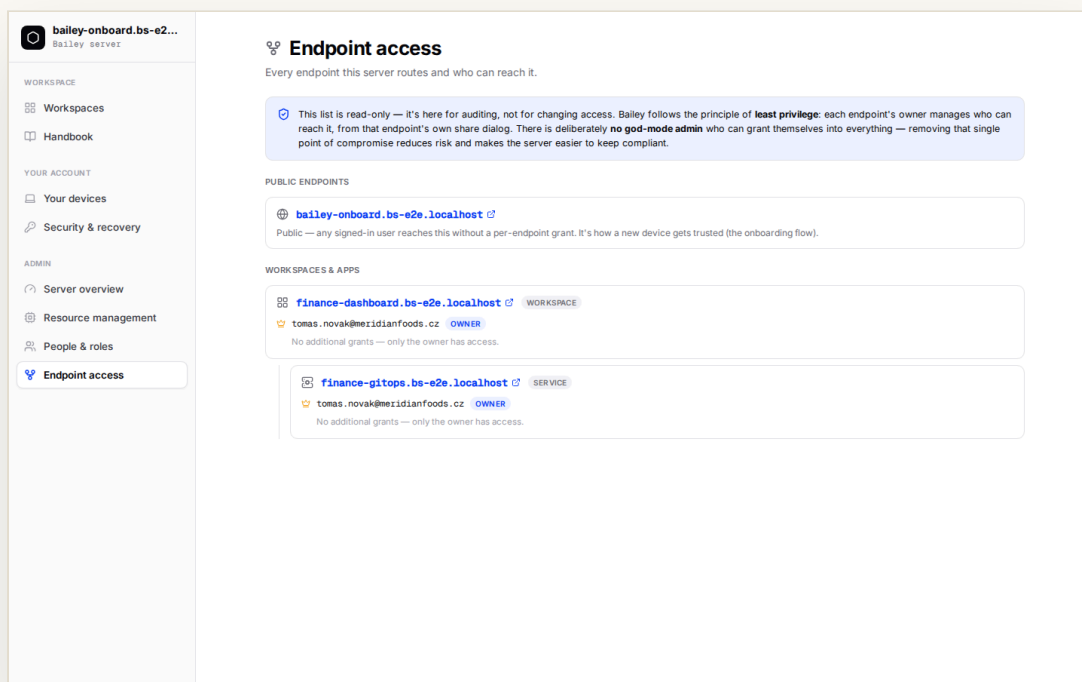
The **Server overview** is the operator's situational awareness: how many workspaces, how many trusted devices, the health of the platform's own services. **Endpoint access** lists every protected hostname the gate fronts — workspace dashboards, gitops, automation frontends — each

with its owner and the workspace it belongs to.

This is your live asset register. When an auditor asks “what is exposed, and who owns it?”, the answer is a page, not an afternoon.

HOW TO

- 1 Open **Server overview** for platform health and counts.
- 2 Open **Endpoint access** to see every protected route.
- 3 Confirm each endpoint has the right owner and workspace.



Server Console · endpoint access — every protected route and its owner



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.5.9

Inventory of information and other associated assets. Every workspace and protected endpoint is enumerated from real, live state.

NIS2

ART. 21(2)(I)

Asset management. The estate of exposed services is inventoried with ownership.

SOC 2

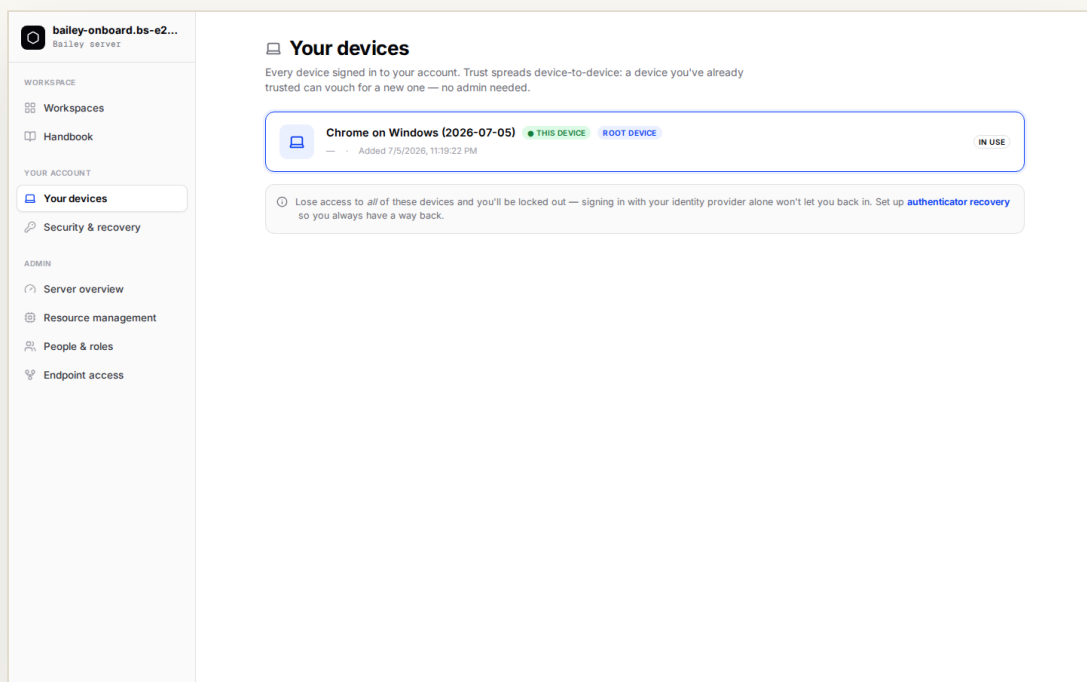
CC6.1

Logical access security. Each endpoint sits behind the gate with an explicit owner.



Your devices

Every browser that reaches the platform is a named, trusted device you can see, label and revoke. Lose a laptop and you cut its access everywhere, instantly.



Server Console · Your devices — trusted hardware, with the root device badged

The **Your devices** page lists the hardware tied to your identity: the *Root device* that claimed the server, any *Admin-approved* or *Linked* devices, which one is in use right now. This is also where you **Link a device** — type the six-digit code a new browser is showing and it's let in.

This is also your **incident response for a stolen or lost device**. Because access is bound to the device, not just the password, a thief who has an unlocked laptop already holds a valid session — rotating the password alone does not lock them out.

Removing the device does: it revokes that device's cookie across the entire platform instantly, so the console and every workspace app stop trusting it the moment you click. The drill is simple and fast — find the lost device in the list, remove it, done — which is exactly why every device is named and badged: so under pressure you can tell which one to cut.

HOW TO

- 1 Open **Your devices** in the console.
- 2 Review trusted devices and their badges.
- 3 To admit a new browser, enter its code under **Link a device**.
- 4 **Lost or stolen device?** Remove it here — its access is revoked everywhere, instantly. That, not a password reset, is the response.

IF A DEVICE IS STOLEN

Device-bound access means a stolen, unlocked laptop is a live session a password change can't stop. The incident response is to **remove the device** — one click revokes its cookie across the console

and every workspace app immediately. Keep devices named so you can identify the one to cut without hesitation.



Bailey is best practice — what the standards ask of you, and how this does it

SOC 2

CC6.2 / CC6.3

Access provisioning & de-provisioning.

Devices are granted and revoked centrally and immediately.

ISO/IEC 27001

A.5.15 / A.8.1

Access control & user-endpoint devices.

Trusted devices are enrolled, labelled and revocable.

NIS2

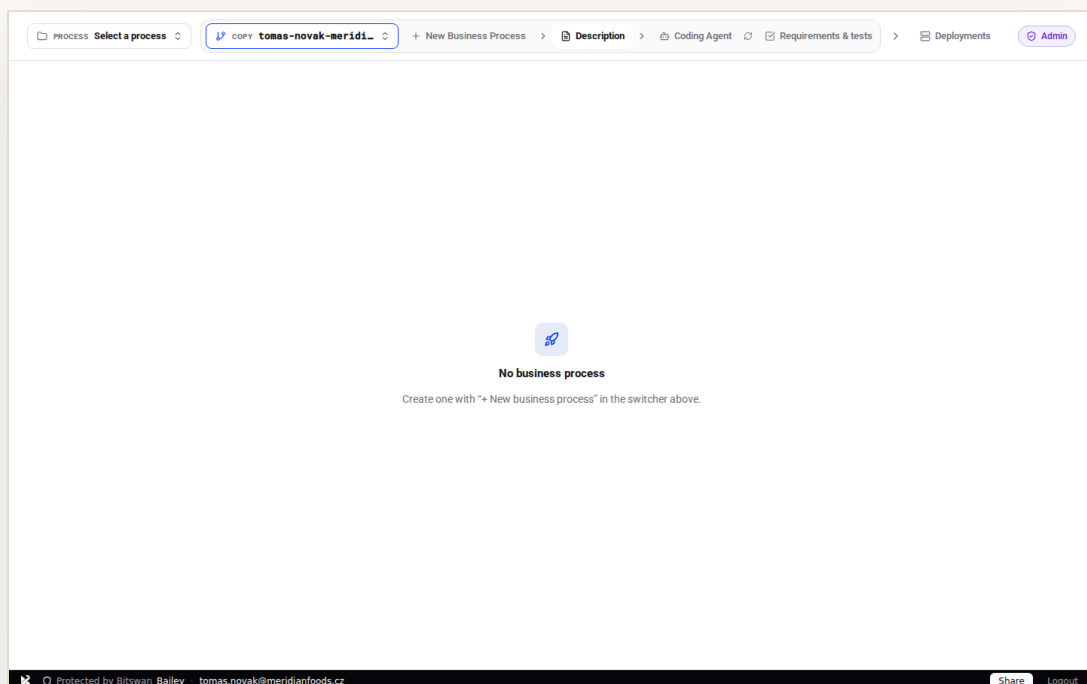
ART. 21(2)(J)

Secured access. Hardware-bound trust is enrolled and managed per person.



The workspace & copies

Open a workspace and you land in its dashboard, working in your own personal copy — an isolated branch where nothing you do touches main until you choose to.



Workspace dashboard · the business-process shell, your personal copy active

Every operator gets a **personal copy** of the workspace — auto-created and auto-selected the moment you open the dashboard. It's your private branch: edit, build and preview without disturbing anyone else's work or the live *main*.

The **copy switcher** (top-right) shows which copy is active, whether it's synced with main, and lets you spin up a *New copy*. Promotion of your

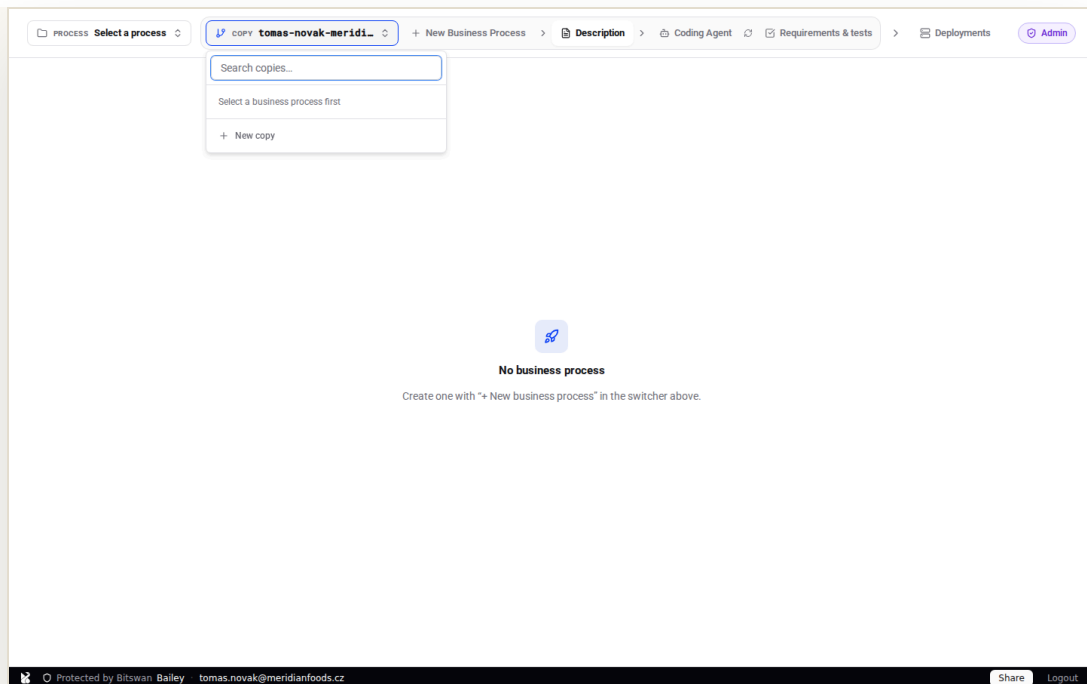
work into main happens deliberately, through Sync & Deploy (Ch 10) — never by accident.

HOW TO

- 1 Press **Open** on the workspace to enter its dashboard.
- 2 Your personal copy is selected automatically.
- 3 Use the **copy switcher** to see sync state or start a new copy.
- 4 Everything you build stays in your copy until you Sync & Deploy.

WHY IT MATTERS

Isolated copies are environment separation by default: experimentation never risks the shared main, and every change reaches production only through a reviewed, deliberate path.



Copy switcher · your copy, its sync state, and “New copy”



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.31

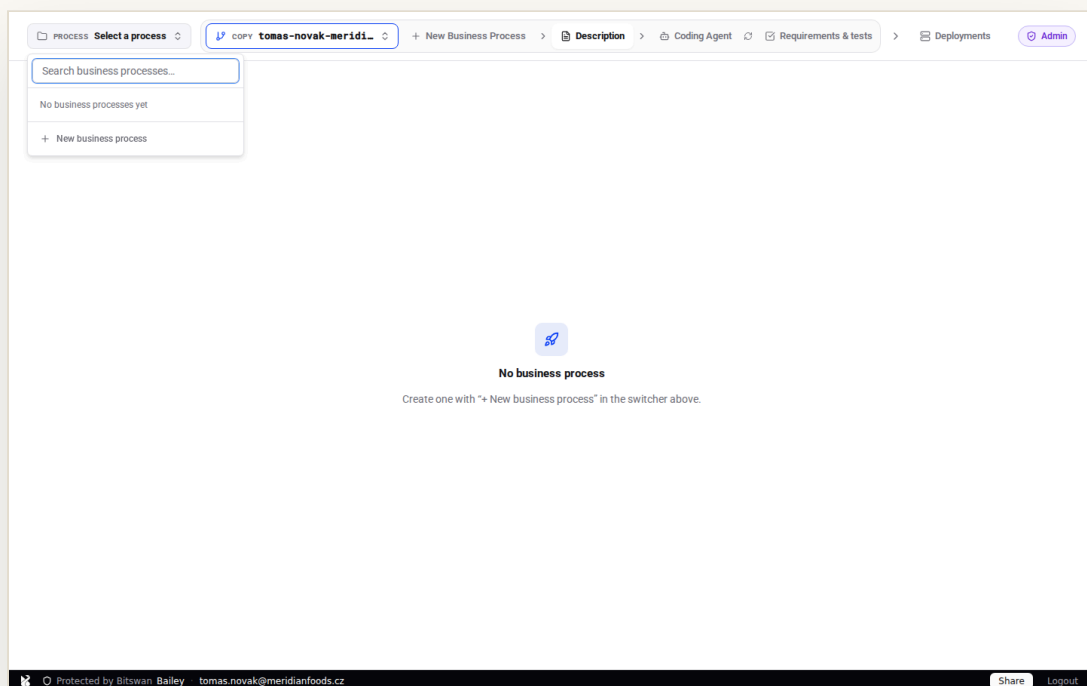
Separation of development, test and production. A personal copy isolates work-in-progress from main and from deployed stages.

SOC 2
CC8.1

Change management. Changes originate in an isolated copy and reach main only through Sync & Deploy.

Business processes

A business process is the unit you build, ship and operate. Create one, and the workspace scaffolds its automations ready to fill in.



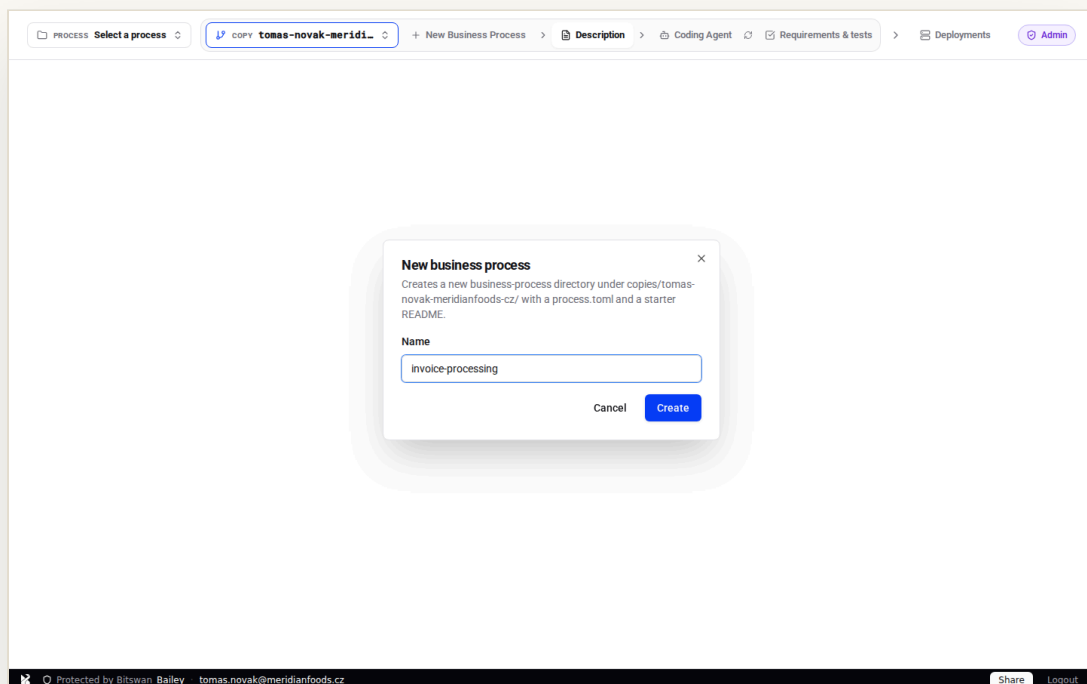
Business-process switcher · select or create a process

Meridian's accounts-payable lives in one business process: **invoice-processing**. The **New business process** modal takes a name (lowercase, hyphenated) and scaffolds its automations — a backend and a frontend — so there's something real to describe, build and deploy.

The process is the boundary for everything that follows: its description, its code, its CVE checks, its stages, its secrets, its backups and its firewall are all scoped to it.

HOW TO

- 1 Open the **business-process switcher** (top-left).
- 2 Click **New business process**.
- 3 Name it in the modal; press **Create**.
- 4 The process is scaffolded and selected.



New business process · naming the invoice-processing process



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.5.9

Inventory of assets. Each business process is a named, owned unit of the estate.

ISO/IEC 27001

A.8.25

Secure development lifecycle. Work is organised per process, with its own pipeline and controls.



Describe the process

Before code, intent. Each business process carries a living specification — what it does, for whom, and the rules it must keep.

The screenshot displays a web-based interface for managing a business process named "invoice-processing". The top navigation bar includes tabs for "PROCESS", "COPY", "New Business Process", "Description", "Coding Agent", "Requirements & tests", "Deployments", and "Admin". Below the navigation bar, the "Description" tab is active, showing a text editor with the following content:

What it does

1. ****Ingest**** – pull invoices (PDF + EDI) from vendor portals and the shared inbox.
2. 1. ****Validate**** – match totals and VAT against the purchase order.
 2. 1. ****Approve**** – anything over ****€5,000**** is held for a human; the rest auto-approves.
 2. 1. ****Post**** – approved invoices post to the ledger and the vendor is paid via the gateway.
3. **The flow**
 3. The lifecycle is drawn below as a flowchart.
3. **Rules it must keep**
 - VAT total must match the purchase order within €0.01.
 - Invoices over €5,000 require human approval before posting.
 - A duplicate invoice number must never post twice.

On the right side of the interface, there is an "Activity" panel showing a list of recent actions:

- Business process "invoice-pro..."** (Done, 2m ago)
- apply template** (Done, 2m ago)
- Applying deployment on the l...** (Running, just now)
- commit changes** (Done, 17s ago)

At the bottom of the interface, there is a status bar indicating protection by Bitwarden Bailey for the user tomas.novak@meridianfoods.cz, along with "Share" and "Logout" buttons.

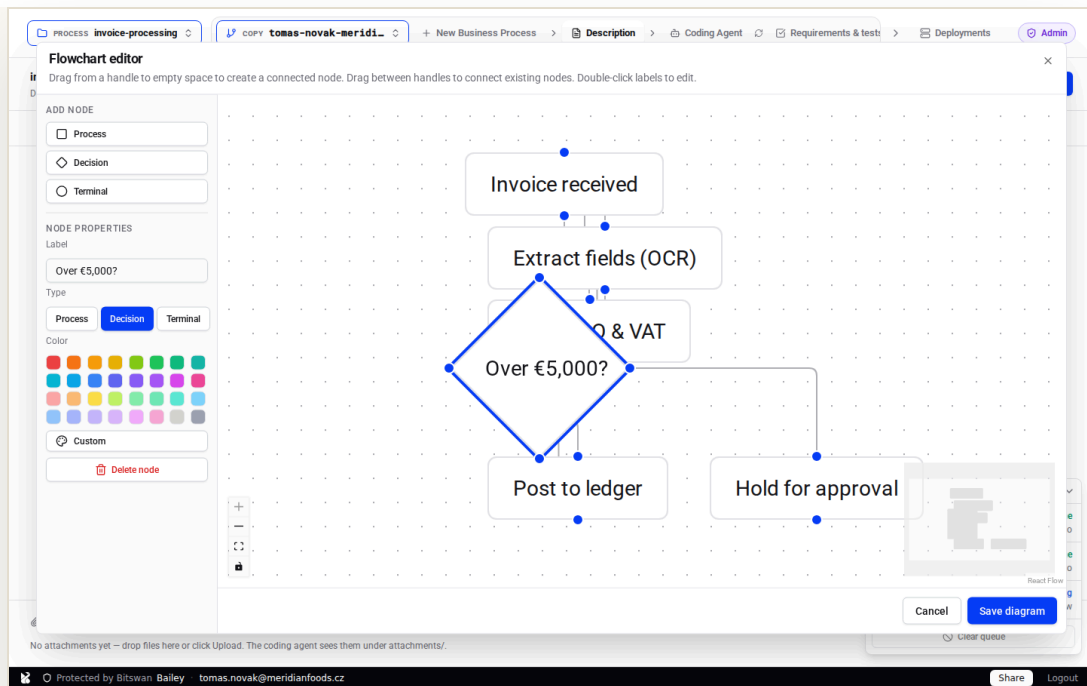
Invoice Processing · the README spec, with the flowchart of the invoice lifecycle drawn into it

Marek documents the **Invoice Processing** spec right in the dashboard: ingest vendor invoices, validate totals and VAT against the PO, route anything over €5,000 for approval, post the rest to the ledger. The editor is rich text with Markdown shortcuts.

For the process flow he doesn't hand-write diagram code — he opens the **flowchart editor** from the toolbar and **draws** it: drop a node (Process, Decision or Terminal), drag from one node's handle to another to connect them, label as he goes, then *Save diagram* drops the rendered flowchart straight into the spec. The description versions *with* the process — documentation that lives next to the code, not in a wiki that drifts. Ctrl+S saves; the indicator confirms it.

HOW TO

- 1 Open the **Description** tab.
- 2 Write the spec in rich text.
- 3 Click the toolbar **Insert flowchart** button and **draw** the flow — add nodes, drag to connect, then **Save diagram**.
- 4 Press **Ctrl+S** — it versions with the process.



Flowchart editor · drawing the invoice flow node-by-node, no diagram syntax to learn



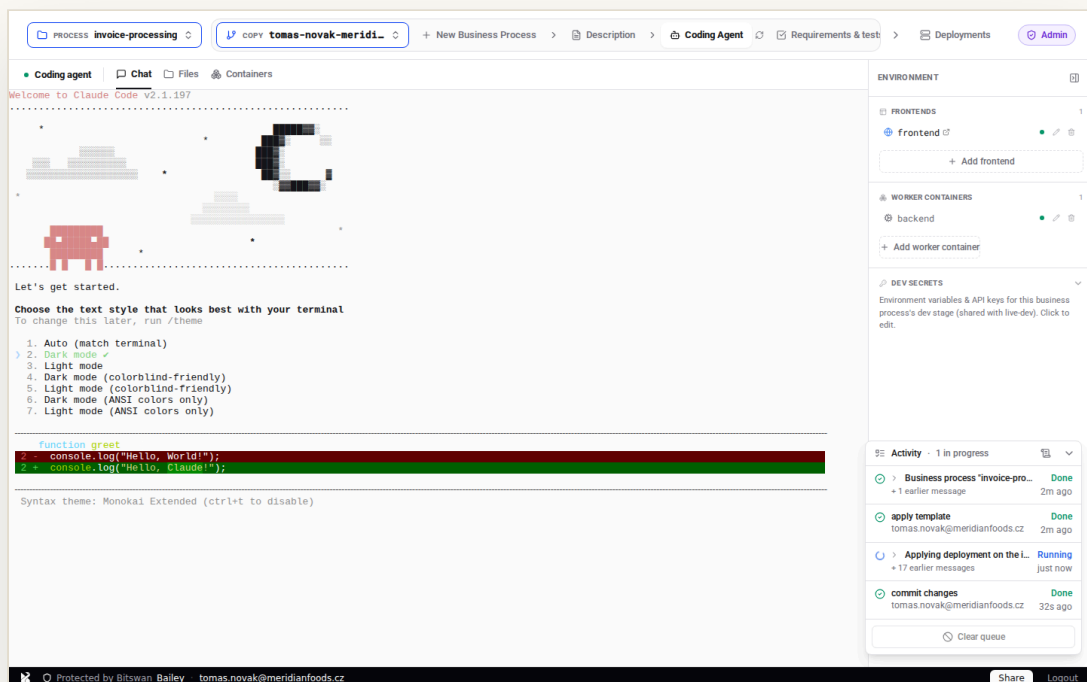
Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.5.37

Documented operating procedures. The process and its rules are written down and kept current alongside the code.

Coding Agent & requirements

Describe the process, then let a coding agent build it — inside the workspace's isolated sandbox — and pin the rules it must keep as runnable requirements.



Coding Agent · the automations of the invoice flow, each with its live-dev preview

The **Coding Agent** works straight from your specification: a terminal and a file tree right in the workspace, writing the invoice-processing automation in your isolated copy you review before it ever reaches main. The point isn't that there's an agent — it's **where** it runs. The agent runs *inside* Bailey, not beside it: it works in

an isolated copy and, while it can reach the internet to do its job, it is **walled off from your production data** — it cannot reach the production database or the user data in it. Everything it produces still passes Sync & Deploy and the CVE checks before it ships.

Each automation in your copy also gets a **live-dev** deployment — a running preview that auto-builds as you change code. To open a running automation you click its **frontend** (the frontend automation's open link in the Environment panel) and click through the real thing in your copy before it touches main. The **Requirements & tests** tab turns the spec's rules into runnable checks — VAT matches the PO, invoices over €5,000 are held, duplicate invoice numbers never post twice — so “does it still do what we promised?” is a button, not a meeting.

HOW TO

- 1 Open the **Coding Agent** tab; start a session against your copy.
- 2 It builds the automation from the Description; the **live-dev** preview comes up.
- 3 Click a running automation's **frontend** to open it and click through it.
- 4 Open **Requirements & tests**; record the rules as runnable specs, then **Sync & Deploy**.

English

Internal Dashboard

This is the internal frontend of your BitSwan Internal App. It is protected by OAuth2 — only employees authorized through the BitSwan Automation Operation Center can access it. Use this dashboard to build secure internal tools for your company.

User Info

Email: tomas.novak@meridianfoods.cz

Username: tomas.novak@meridianfoods.cz

Sign Out

Token Info

Issued: 11:19:21 PM

Expires: 11:24:21 PM

TTL: -278s (expired)

Backend says: Hello from Go!

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz

ShareLogout

Live-dev · the automation running its live preview in your copy — click its frontend to open it

PROCESS invoice-processing

COPY tomas-novak-meridi...

+ New Business Process

Description

Coding Agent

Requirements & tests

Deployments

Admin

3 TOTAL · 3 PENDING

Write tests

+ New requirement

Search id or description...

AllPendingPassFailRetestProposed

REQ-001	PENDING	VAT matches the PO
REQ-002	PENDING	Invoices over €5,000 are held for approval
REQ-003	PENDING	Duplicate invoice numbers never post twice

Activity · 4 recent

Business process "invoice-pro...
+ 1 earlier message

Done8m ago

apply template
tomas.novak@meridianfoods.cz

Done8m ago

invoice-processing ready
+ 18 earlier messages

Done6m ago

commit changes
tomas.novak@meridianfoods.cz

Done7m ago

Clear queue

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz

ShareLogout

Requirements & tests · the rules the process must keep, as runnable specs



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.25 / A.8.31

Secure development lifecycle & environment separation. The agent builds in an isolated copy/sandbox, never touching production directly.

NIS2

ART. 21(2)(E)

Security in development. Agent output is CVE-scanned and reviewed before deploy.

SOC 2

CC6.6

Boundary protection. The agent's egress is constrained by the workspace firewall allow-list.

DORA

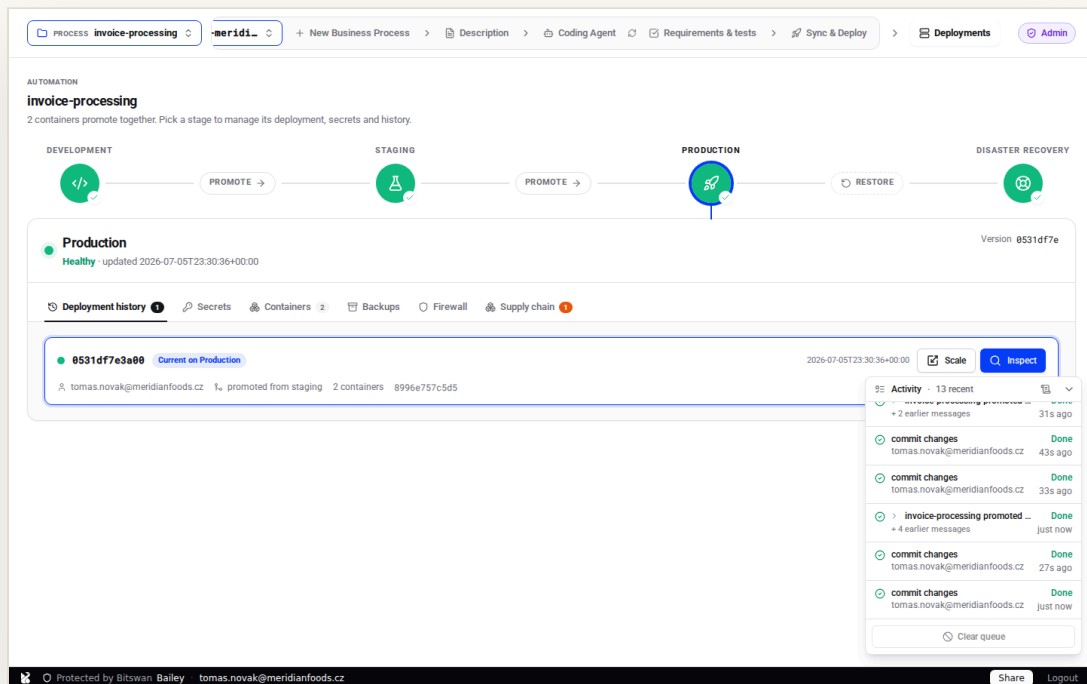
ART. 24–26

Resilience testing. Requirements are runnable specifications, re-run on demand.



Dev, staging & production

A business process promotes through three stages — Development, Staging and Production — and each one runs on its own database, its own file store and its own isolated Docker network. The data of one stage is never the data of another, and the stages literally cannot reach each other.



Deployments · the dev → staging → production pipeline, each stage its own isolated database + file store

Meridian's invoice-processing process doesn't go straight to production. It promotes through three stages — **Development** → **Staging** → **Production** — and the point of the split is isolation: each stage has **its own database, its own file store and its own Docker network**, so the

records, attachments and ledger entries in one stage are never the records of another — and because the networks are separate, the stages **literally cannot talk to each other**. User and production data is **never shared** across the line. That means you can run the application in dev and exercise it hard in staging — wrong totals, malformed VAT numbers, deliberate edge cases — **without ever touching real production data**, because the data simply isn't there to touch.

The split is also **who**, not just **where**. Because production is its own stage with its own gate, an experienced team member can **audit and review the code before it reaches production**: a member builds and ships through dev and staging, and promotion to production is a deliberate, reviewable step rather than an accident. That separation of duties — build over here, sign off over there — is exactly what an auditor expects to see, and it falls out of the stage model rather than being bolted on.

HOW TO

- 1 Open **Deployments** and read the pipeline: **Development, Staging, Production**.
- 2 Build and test in **Development** against its own isolated database and file store.
- 3 Promote to **Staging** and exercise the app on staging's own data — never production's.
- 4 Have an experienced reviewer sign off before the deliberate promotion to **Production**.

WHY IT MATTERS

Three stages, three databases, three file stores, three isolated Docker networks — the stages cannot even reach one another. Testing in dev and staging can never expose or corrupt real production data, and

production changes pass through a reviewable promotion — separation of duties and environment isolation, by construction.



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.31

Separation of development, test and production environments. Dev, staging and production each run on their own database, file store and Docker network — the stages cannot reach one another and production data is never present in a test stage.

SOC 2

CC8.1

Change management. Changes are built and tested in lower stages and reach production only through a deliberate, reviewable promotion.

GDPR

ART. 5(1)(C)

Data minimisation. Real personal data lives only in production; dev and staging are tested without using production user data.



Sync & Deploy

From a working copy to a healthy deployment — with the diff, the history and a security check standing between you and production.

The screenshot shows the 'Sync & Deploy' interface for a business process named 'invoice-processing'. The interface includes a breadcrumb trail: PROCESS invoice-processing > meridi... > + New Business Process > Description > Coding Agent > Requirements & tests > Sync & Deploy > Deployments > Admin. The 'Sync & Deploy' section explains that it rebases 'tomas-novak-meridianfoods-cz' onto the 'main code area', builds and deploys every container in the business process to 'dev', and that changes become the new main once the deploy succeeds. It shows 'THIS BUSINESS PROCESS' is 'T 2 ahead' with '38 uncommitted files' and a diff of '+2050 -0'. Below this is a 'Diff' table with columns for 'Diff', 'History', and 'Checks'. The table lists 38 files, all marked as 'added', including 'invoice-processing/README.md', 'invoice-processing/backend/auth.go', 'invoice-processing/backend/automation.toml', 'invoice-processing/backend/db.go', 'invoice-processing/backend/go.mod', 'invoice-processing/backend/go.sum', 'invoice-processing/backend/handlers_internal.go', 'invoice-processing/backend/handlers_public.go', 'invoice-processing/backend/image/Dockerfile', 'invoice-processing/backend/image/air.toml', and 'invoice-processing/backend/image/entrypoint.sh'. A 'Sync & Deploy' button is in the top right. An 'Activity' panel on the right shows recent events: 'Business process "invoice-pro..." Done 8m ago', 'apply template tomas.novak@meridianfoods.cz Done 8m ago', 'invoice-processing ready Done 6m ago', and 'commit changes tomas.novak@meridianfoods.cz Done 7m ago'. The footer shows 'Protected by BitSwan Bailey tomas.novak@meridianfoods.cz' and 'Share Logout' buttons.

Sync & Deploy

Rebases **tomas-novak-meridianfoods-cz** onto the **main code area**, then builds and deploys every container in this business process to **dev**. Your changes below become the new main once the deploy succeeds.

THIS BUSINESS PROCESS T 2 ahead 38 uncommitted files +2050 -0

Diff History Checks

38 FILES +2050

added	invoice-processing/README.md	+36
added	invoice-processing/backend/auth.go	+189
added	invoice-processing/backend/automation.toml	+13
added	invoice-processing/backend/db.go	+163
added	invoice-processing/backend/go.mod	+1
added	invoice-processing/backend/go.sum	+1
added	invoice-processing/backend/handlers_internal.go	+102
added	invoice-processing/backend/handlers_public.go	+56
added	invoice-processing/backend/image/Dockerfile	+17
added	invoice-processing/backend/image/air.toml	+15
added	invoice-processing/backend/image/entrypoint.sh	+16

Select a file to view its diff.

Activity 4 recent

- Business process "invoice-pro..." Done 8m ago
- apply template tomas.novak@meridianfoods.cz Done 8m ago
- invoice-processing ready Done 6m ago
- commit changes tomas.novak@meridianfoods.cz Done 7m ago

Clear queue

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz

Share Logout

Sync & Deploy · ready to ship invoice-processing to development

One button does the careful thing: commit work-in-progress, rebase your copy onto main, fast-forward, and roll out to development — **tracking the single deploy it started** rather than racing a second one. While it works, the button reads *Working...* and the live deploy step streams into a toast.

Around the button are the three things you check before shipping: the **Diff** (exactly what becomes main), the **History** (your copy's and main's commits, with deploy markers), and the **Checks** tab — the precise CVEs of the image this deploy *would* build. Click any CVE for its advisory; record what's out of scope into your source tree, where review can see it.

HOW TO

- 1 Open **Sync & Deploy**.
- 2 Review the **Diff**, the **History**, and the **Checks** tab.
- 3 Press **Sync & Deploy** — dev goes **Healthy**.
- 4 Promote when you're ready.

WHY IT MATTERS

The check happens on the image that will actually run — not last week's scan. Security is a step in the flow, not a gate someone forgets.

PROCESS

invoice-processing

meridi...

+ New Business Process

Description

Coding Agent

Requirements & tests

Sync & Deploy

Deployments

Admin

Sync & Deploy

Rebases **tomas-novak-meridianfoods-cz** onto the **main** code area, then builds and deploys every container in this business process to **dev**. Your changes below become the new main once the deploy succeeds.

THIS BUSINESS PROCESS
1 2 ahead
38 uncommitted files
+2850
-0

Diff

History

Checks

web

TOMAS-NOVAK-MERIDIANFOODS-CZ

tomas.novak@meridianfoods.cz · 7/5/2026, 11:21:00 PM

Create business proc...

tomas.novak@meridianfoods.cz · 7/5/2026, 11:21:00 PM

MAIN

8c136d6 Initialize busi...

tomas.novak@meridianfoods.cz · 7/5/2026, 11:21:00 PM

Select a file to view its diff.

Activity · 4 recent

Business process "invoice-pro...

+ 1 earlier message

Done

8m ago

apply template

tomas.novak@meridianfoods.cz

Done

8m ago

invoice-processing ready

+ 18 earlier messages

Done

6m ago

commit changes

tomas.novak@meridianfoods.cz

Done

7m ago

Clear queue

Protected by BitSwan Bailey

tomas.novak@meridianfoods.cz

Share

Logout

History sub-tab · copy + main commits with deploy markers

PROCESS

invoice-processing

meridi...

+ New Business Process

Description

Coding Agent

Requirements & tests

Sync & Deploy

Deployments

Admin

Sync & Deploy

Rebases **tomas-novak-meridianfoods-cz** onto the **main** code area, then builds and deploys every container in this business process to **dev**. Your changes below become the new main once the deploy succeeds.

THIS BUSINESS PROCESS
UP TO DATE WITH MAIN

Diff

History

Checks

Vulnerabilities in the image this business process would build from **tomas-novak-meridianfoods-cz**'s current source – the same artifact **Sync & Deploy** ships. Built and scanned on demand. Click a CVE to view it or mark it out of scope – that decision is saved with the code and ships on Sync & Deploy.

1 High

13 Medium

3 Low

PACKAGE	VERSION	VULNERABILITIES
undici	6.26.0	GHSA-35p6-xmwp-9g52 GHSA-g8m3-5g56-fq7m GHSA-p88m-4jfj-68fv GHSA-vxpw-j846-p89q
github.com/gohugoio/hugo	v0.134.3	GHSA-c2xf-0v2r-r2rx GHSA-c3wq-j5vh-68rc GHSA-c54g-xjwj-8g82 GHSA-fw87-fv5r-9fpw GHSA-bcv8-8b8x-48pg GHSA-q76j-gcg9-vxc6 GHSA-vxgn-5rag-5w8g GHSA-x597-9fr4-5857
busybox	1.37.0-r31	CVE-2025-68876
busybox-binsh	1.37.0-r31	CVE-2025-68876
ssl_client	1.37.0-r31	CVE-2025-68876
tar	7.5.15	GHSA-vmf3-w455-68vh
golang.org/x/sys	v0.25.0	GO-2025-5824

363 packages · 17 in-scope CVEs · scanned 7/5/2026, 11:29:48 PM

Activity · 6 recent

Business process "invoice-pro...

+ 1 earlier message

Done

9m ago

apply template

tomas.novak@meridianfoods.cz

Done

9m ago

invoice-processing ready

+ 18 earlier messages

Done

7m ago

commit changes

tomas.novak@meridianfoods.cz

Done

8m ago

invoice-processing synced an...

+ 4 earlier messages

Done

just now

commit changes

tomas.novak@meridianfoods.cz

Done

56s ago

Clear queue

Protected by BitSwan Bailey

tomas.novak@meridianfoods.cz

Share

Logout

Checks sub-tab · CVEs of the image this deploy would build



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.8

Management of technical vulnerabilities. The image is CVE-scanned before it ships, with each finding linked to its advisory.

NIS2

ART. 21(2)(E)

Security in acquisition, development and maintenance, incl. vulnerability handling. Waivers are versioned in-tree and reviewable.

DORA

ART. 8–9

ICT risk identification & protection. Pre-deploy scanning makes risk identification automatic and auditable.

SOC 2

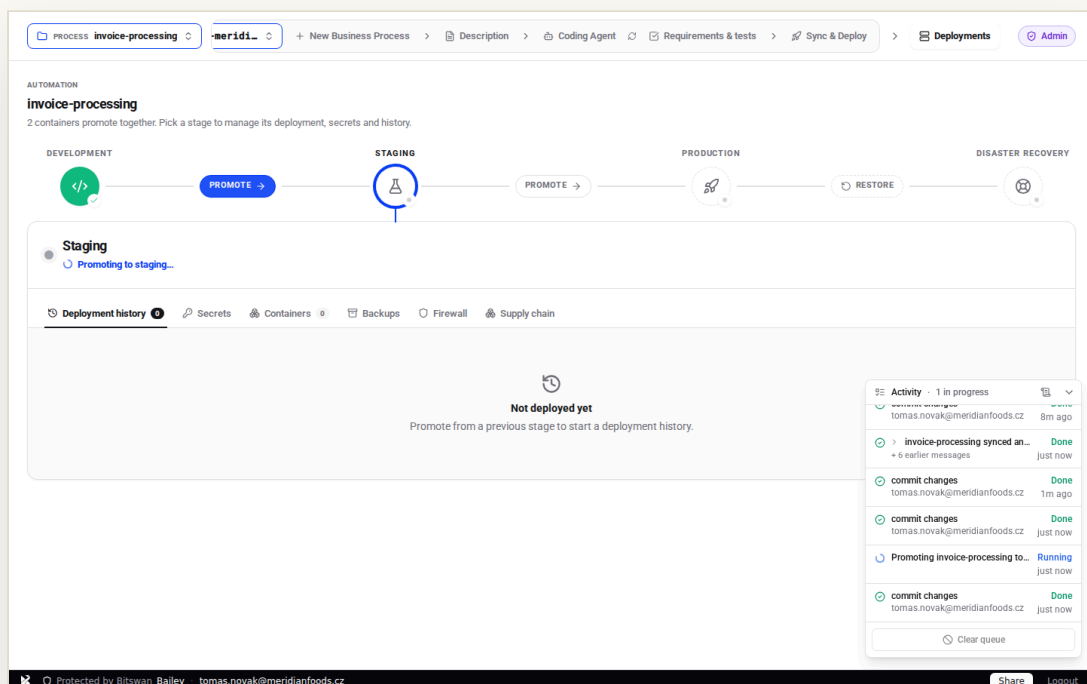
CC8.1

Change management. Commit, rebase, deploy is one controlled, observable operation.



Blue-green production

Three app slots over two persistent databases. The live slot owns production; the standby owns DR; the third is your zero-downtime buffer.



Promotion in flight (dev → staging) · the idle slot coming up, the live step streaming, before the cutover

Promote dev → staging → production
and the idle slot comes up on the live
database, ingress repoints, the old
slot retires. The pipeline tells you
what it's doing the whole way — the
stage card streams its live step as the
standby slot builds and starts.
Promotion re-deploys the source
stage's recorded image verbatim —
what reaches production is exactly
what you tested, even if the

workspace source has moved on.
Users never see a gap.

Production is a state you can read at a glance: which slot is live, which is standby, what's **Healthy**, and the version each stage is current on.

HOW TO

- 1 Open **Deployments** → **Development**.
- 2 Press **Promote** to staging, then to production.
- 3 Watch each stage report **Healthy** on screen.
- 4 Confirm Production shows the version you shipped.

3 slots

a / b / c app slots

2 DBs

persistent, slot-aware

0 s

downtime on promote

The screenshot displays the Meridian deployment interface for an automation named 'invoice-processing'. The top navigation bar includes links for 'PROCESS', 'invoice-processing', 'meridi...', '+ New Business Process', 'Description', 'Coding Agent', 'Requirements & tests', 'Sync & Deploy', 'Deployments', and 'Admin'. Below the navigation bar, the 'AUTOMATION' section shows a workflow with stages: DEVELOPMENT, STAGING, PRODUCTION, and DISASTER RECOVERY. The 'PRODUCTION' stage is currently selected and highlighted with a blue circle. Below the workflow, the 'Production' section shows a status of 'Promoting to production...'. A 'Deployment history' section is visible, showing a message 'Not deployed yet' and 'Promote from a previous stage to start a deployment history.' On the right side, an 'Activity' panel shows a list of recent actions, including 'invoice-processing promoted...', 'commit changes', and 'Promoting invoice-processing to...'. The bottom of the interface shows a footer with 'Protected by BitSwan Bailey', the user 'tomas.novak@meridianfoods.cz', and buttons for 'Share' and 'Logout'.

Promotion in flight (staging → production) · the standby slot building on the live database before the production cutover

The screenshot displays the BitSwan Bailey deployment interface for a process named 'invoice-processing'. The interface shows a deployment pipeline with stages: DEVELOPMENT, STAGING, PRODUCTION, and DISASTER RECOVERY. The 'PRODUCTION' stage is currently active and healthy. The deployment history table shows a recent deployment of version '0531df7e3a00' to the 'Production' stage. The activity panel on the right shows a list of recent events, including 'commit changes' and 'invoice-processing promoted'.

Deployments · Production Healthy after promote, every stage green



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.32

Change management. Production changes follow a controlled, reversible promotion path.

ISO/IEC 27001

A.8.31

Separation of development, test and production. The dev / staging / production stages keep environments cleanly separated within a process.

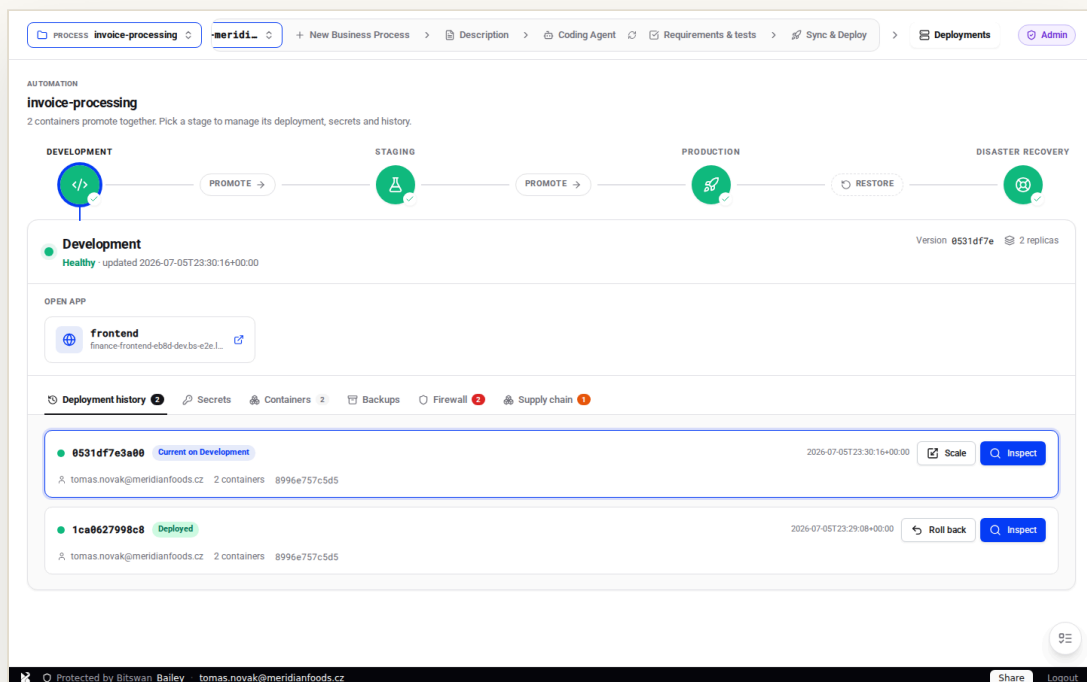
DORA

ART. 9

Protection & prevention. Minimise the impact of changes on the availability of critical functions.

Deployment history & inspect

A versioned, immutable audit log: every deploy, promotion, swap, backup and firewall change — and a per-deployment Inspect with the files, diff and secrets in force at the time.



Deployment history · the audit trail of every event, with Inspect and Roll back per entry

Who shipped what, when, on which commit, and what changed — including backup, restore, swap and retention events. The history is derived from the versioned record, so it can't be quietly edited. Each entry is a rollback point: **Roll back** re-deploys that exact recorded version (its image, verbatim) and records the

action as a new *rolled back* entry at the top of the timeline — so recovering from a bad change is a click and a confirmation, not a scramble, and the recovery itself is auditable.

What makes the trail trustworthy is the canonical `main` branch itself: it is a **protected branch that accepts only fast-forward merges**. Every deploy advances `main` forward — never a force-push, never a rebase that rewrites what came before — so history can only be **appended to, never rewritten**. There is no `git push --force` that quietly erases a deploy, and no way for the operator (or anyone) to go back and edit the record of what shipped. The append-only commit graph *is* the audit log: it is immutable by construction, not by policy, so when an auditor asks whether the deployment history could have been tampered with, the answer is that the branch protection makes it impossible.

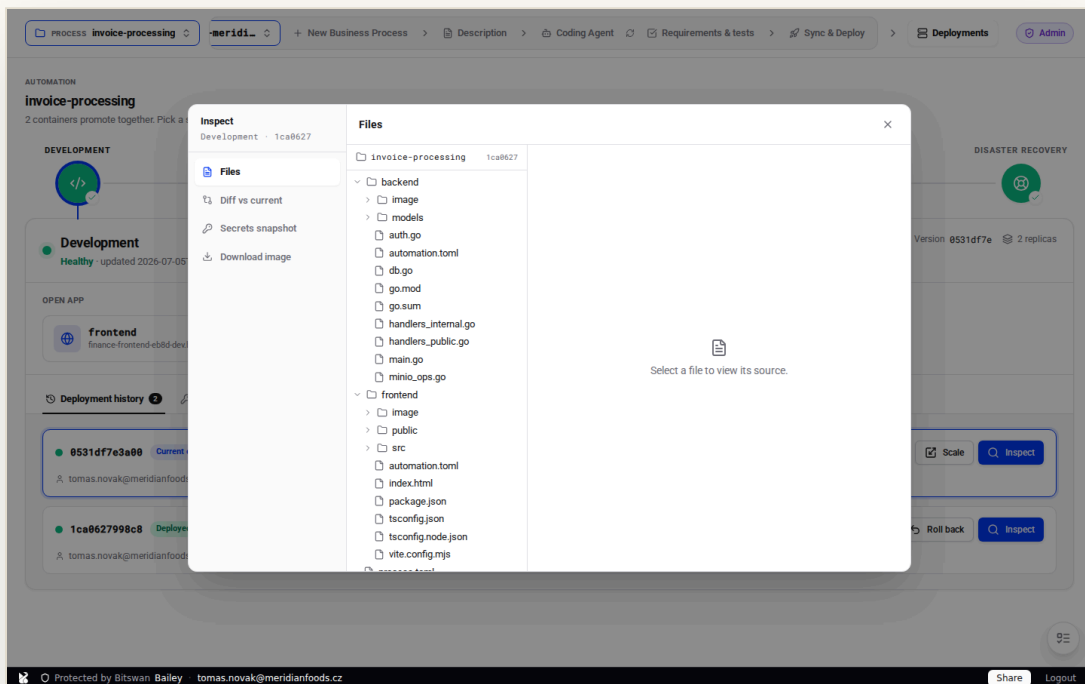
Open **Inspect** on any deployment and you get the receipts across several tabs — *Files* (the exact source tree it ran), *Diff vs current* (what changed versus what's live), *Secrets snapshot* (the secret set in force), *Download image* (the built image + schema bundle), and, on the current deployment, *Scale*. When an auditor asks “show me”, you open a tab.

HOW TO

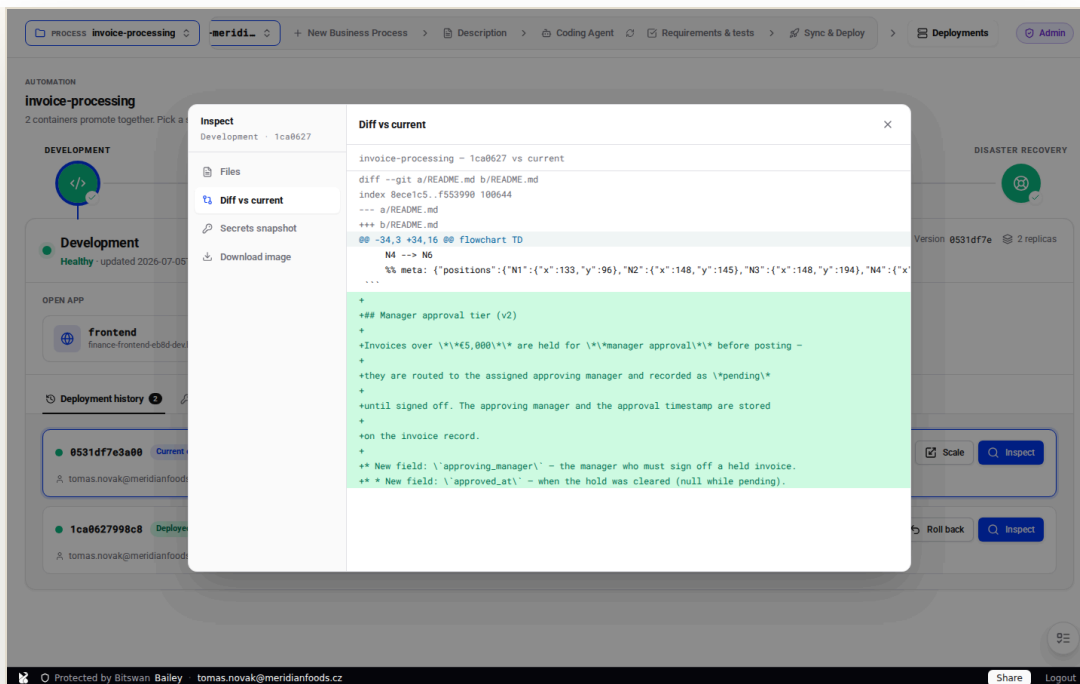
- 1 Open a stage → **Deployment history**.
- 2 Read the timeline of events.
- 3 Press **Inspect** on a prior entry; step through **Files**, **Diff vs current** (a real diff against what's live) and **Download image**.
- 4 Press **Roll back** on a prior entry and confirm to re-deploy that exact recorded version.

AN AUDIT LOG YOU CAN'T TAMPER WITH

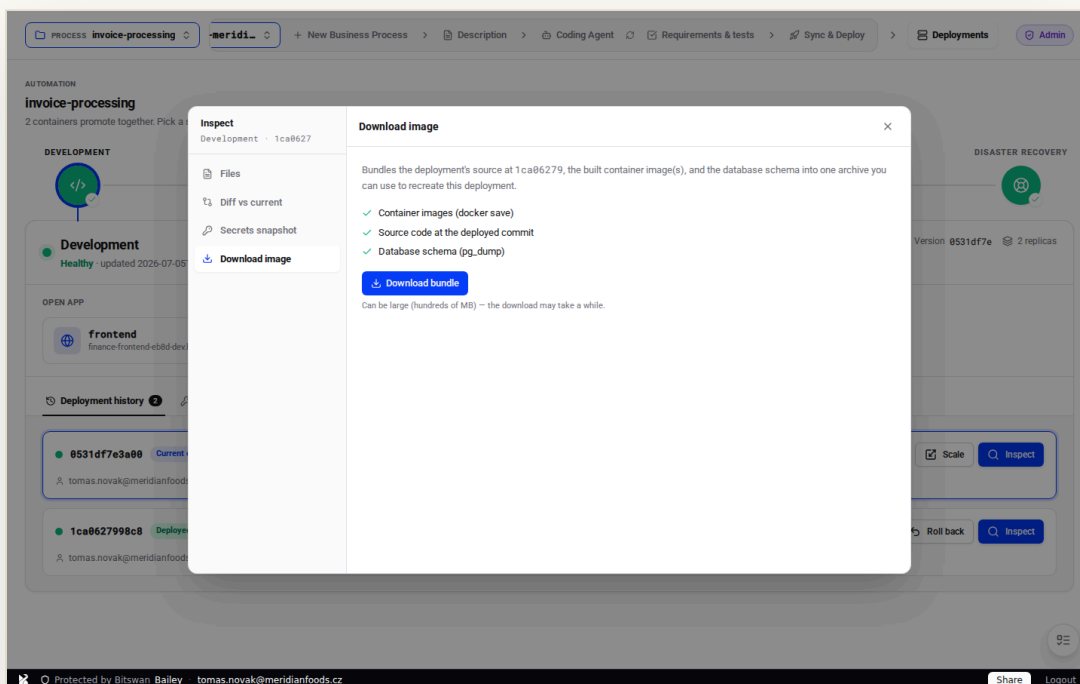
The canonical `main` branch is protected and **fast-forward-only** — every deploy advances it forward, never a force-push or a rewrite. History can only be appended to, so the deployment record is immutable *by construction*. Even the operator cannot quietly edit what shipped: the branch protection, not a promise, is what makes the trail tamper-proof.



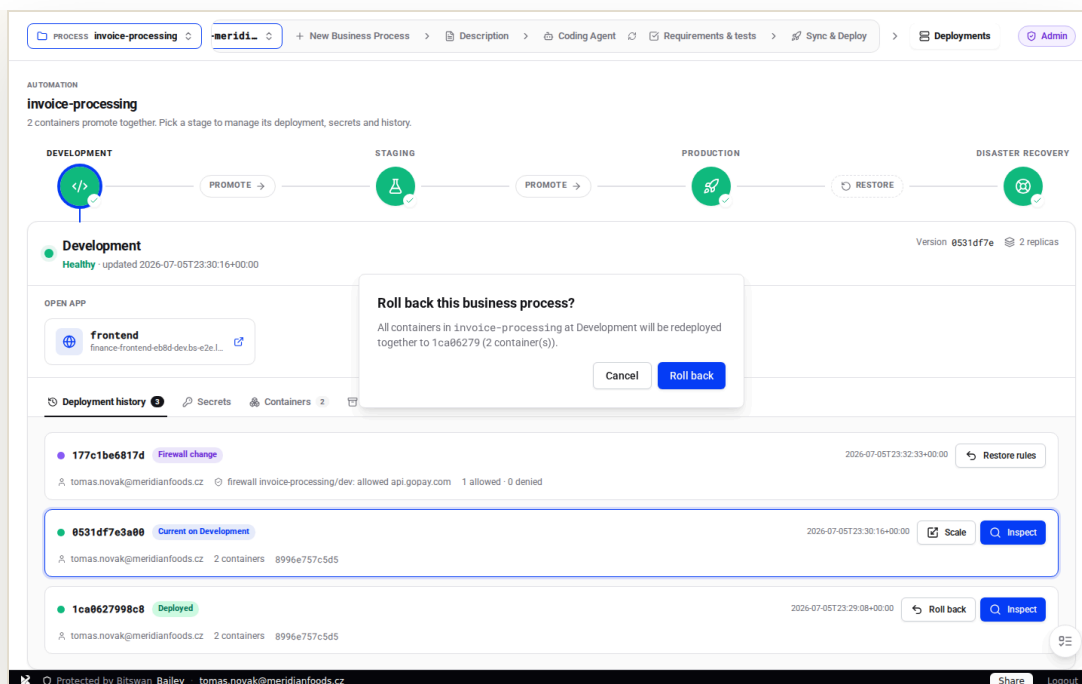
Inspect · the source file tree of exactly what this deployment ran



Inspect → Diff vs current · what changed between this deployment and what's live now



Inspect → Download image · the built image + schema bundle for offline audit



Roll back · the confirmation before re-deploying a prior recorded version



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.15

Logging (integrity & tamper-protection).

Operational events are recorded on a fast-forward-only protected main — append-only and rewrite-proof, so the log is protected from tampering by construction, including by the operator.

DORA
ART. 13

Learning and evolving. A complete record supports post-incident review.

NIS2
ART. 21(2)(B)

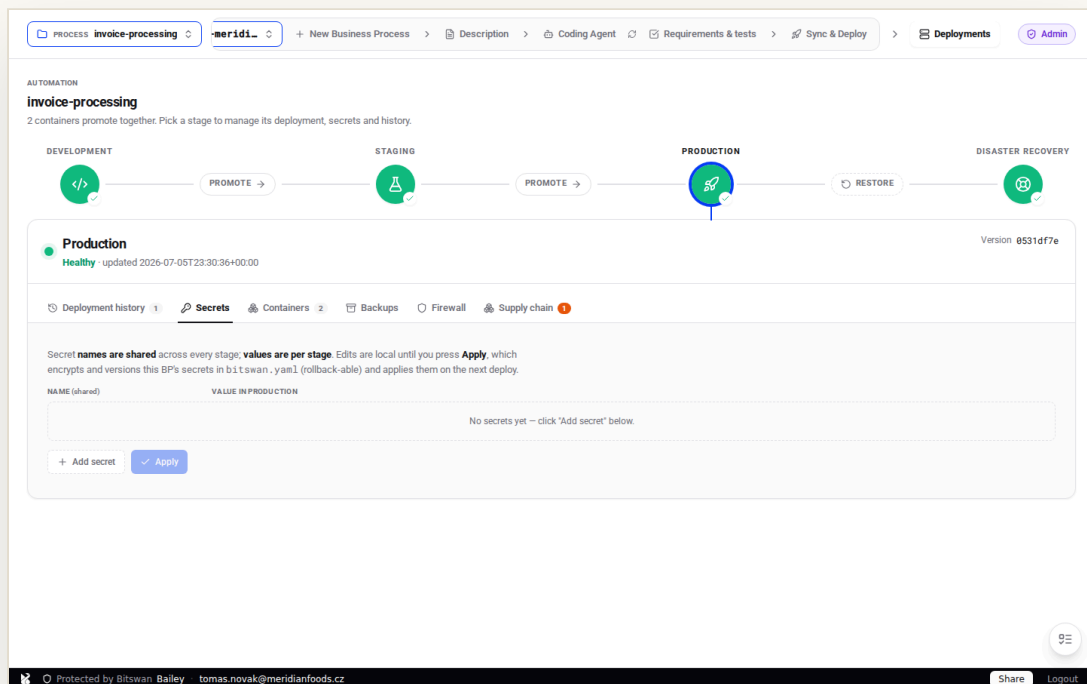
Incident handling. Reconstruct exactly what happened from the audit trail.

SOC 2
CC8.1

Change management. Every change is recorded with its diff and the config in force.

Secrets

Per-stage environment secrets, write-gated by role, injected at deploy and snapshotted with every deployment.



Production · environment secrets, role-gated

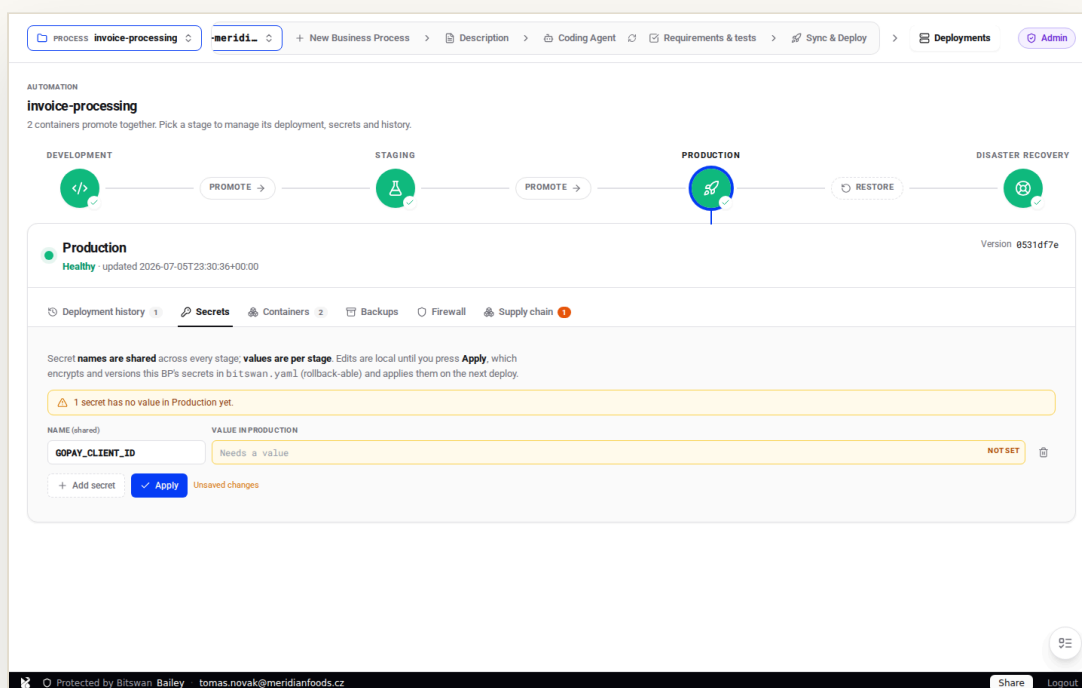
The payment-gateway credentials and the approval threshold live as **stage secrets**: shared names, per-stage values. Members read; admins and auditors write. You add a key and value right in the dashboard, and it's injected on the next deploy of that stage — never written into the repo.

Every deployment captures the secret set in force at that moment, so an Inspect of any historical deploy shows exactly which secrets it ran with. No

secrets in the repo, no secrets in a chat thread.

HOW TO

- 1 Open a stage → **Secrets**.
- 2 Add keys (gateway id, threshold...) with their values.
- 3 They're injected at deploy, never committed.
- 4 Each deploy snapshots the secret set in force.



Adding a stage secret — key + value, never committed to source



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.24

Use of cryptography & secret management.

Secrets are stored and injected securely, separated from source.

NIS2

ART. 21(2)(H)

Cryptography and, where appropriate, encryption. Sensitive material is handled as such by default.

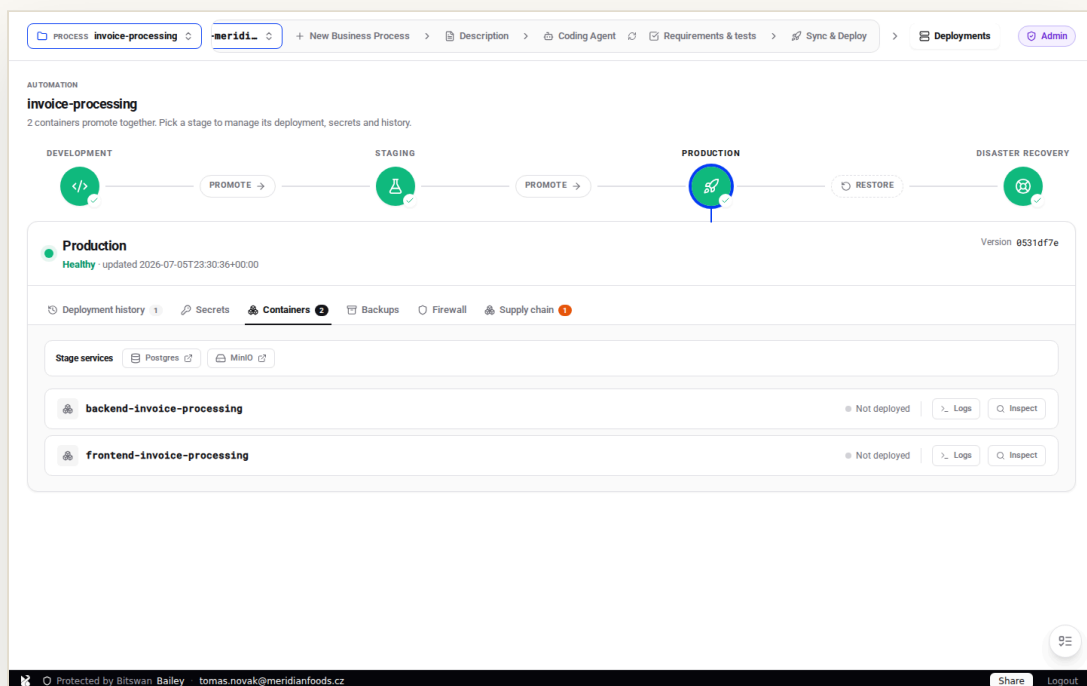
GDPR

ART. 32

Security of processing. Credentials that protect personal data are kept out of source and role-gated.

Containers

The live container roster for a stage — every service of the deployment, its health, and per-container Logs, Inspect, and start/stop controls.



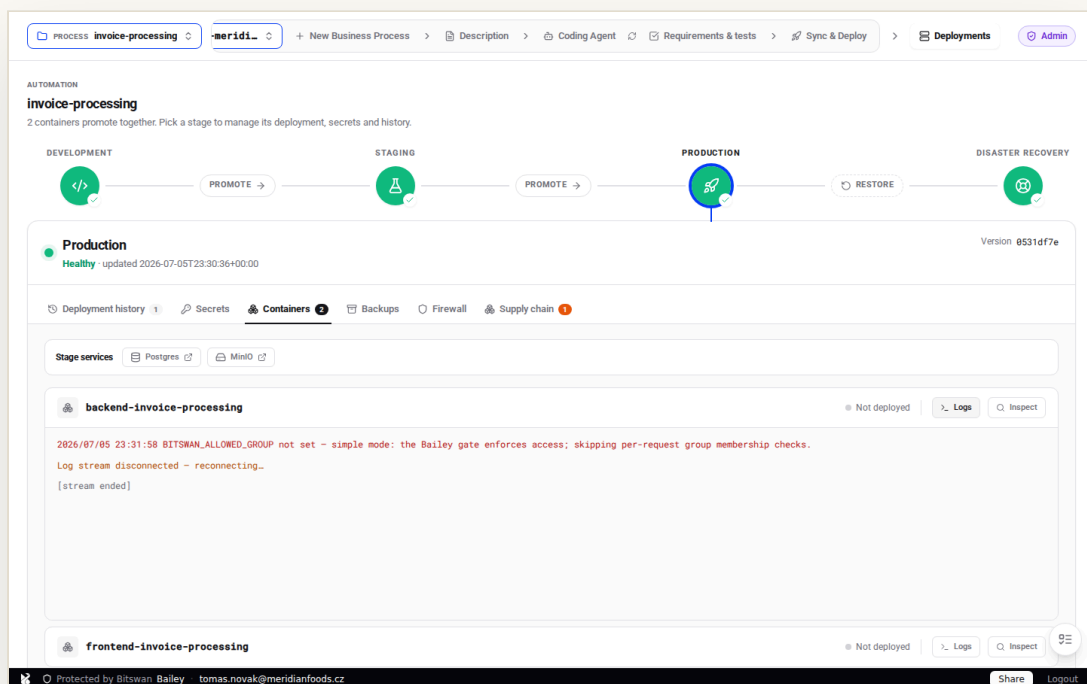
Production · the live containers of the current deployment

The **Containers** section is the operator's ground truth for a stage: each member of the deployment as a real running container, with its status. Open *Logs* to read what it's doing, *Inspect* for its configuration, or restart/stop a single service without touching the rest.

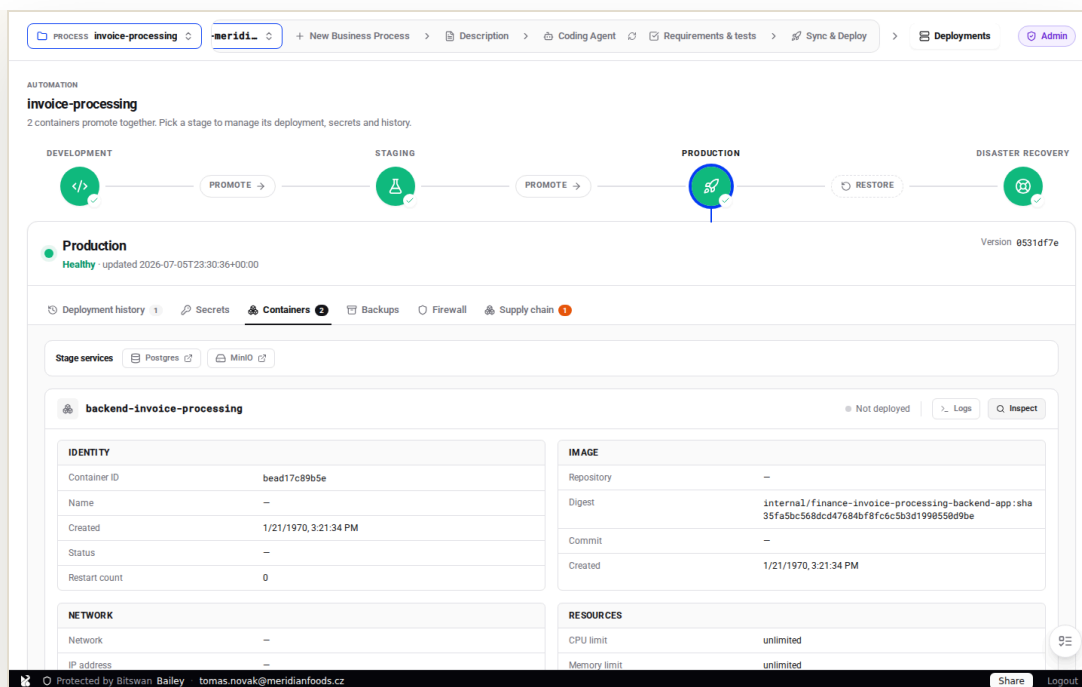
On Disaster Recovery, each container resolves to the standby slot's own instance — so you operate the recovered app, not the live one.

HOW TO

- 1 Open a stage → **Containers**.
- 2 Read status per service.
- 3 Use **Logs** / **Inspect** to investigate.
- 4 Restart or stop a single container if needed.



Container logs · the live log stream of a running service, read straight from the deployment



Container inspect · the service's configuration — identity, image, network — at a glance



Bailey is best practice — what the standards ask of you, and how this does it

SOC 2

CC7.2

System monitoring. Container health is visible per service, per stage.

DORA

ART. 10

Detection. Operators can observe the live state of every running service.

ISO/IEC 27001

A.8.16

Monitoring activities. The running estate is observable in real time.

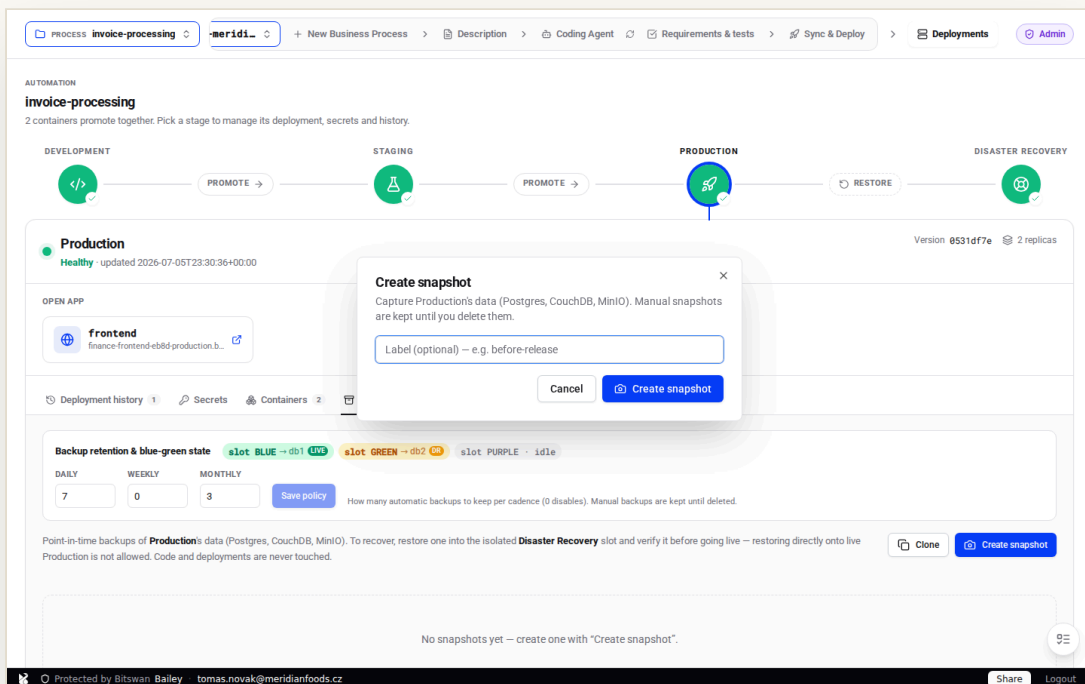


BitSwan Bailey · The Operator's Handbook

Containers — 14

Backups & retention

Point-in-time snapshots of the live database and object storage, with a retention policy and an audit trail.



Create snapshot · label and stage, before it runs

The **Create snapshot** dialog lets you label a snapshot and pick its stage; confirm and a task captures the **live blue-green database** — not a stale name — plus object storage, streaming its progress per store (Postgres, CouchDB, MinIO) so it never goes dark.

The result is a snapshot you can see, size, restore and clone between stages. Retention is a policy, not a cron job someone half-remembers.

HOW TO

- 1 Open **Production** → **Backups**.
- 2 Press **Create snapshot**; label it.
- 3 Watch it run; it lists with size and contents.

4 Set the retention policy.

invoice-processing

2 containers promote together. Pick a stage to manage its deployment, secrets and history.

DEVELOPMENT STAGING PRODUCTION DISASTER RECOVERY

Production Healthy updated 2026-07-05T23:30:36+00:00 Version 6531df7e 2 replicas

OPEN APP

frontend finance-frontend-e8bd-production.b...

Deployment history 1 Secrets Containers 2 Backups Firewall Supply chain 1

Backup retention & blue-green state slot BLUE - db1 LIVE slot GREEN - db2 slot PURPLE - idle

DAILY WEEKLY MONTHLY

7 0 3 Save policy How many automatic backups to keep per cadence (0 disables). Manual backups are kept until deleted.

Point-in-time backups of Production's data (Postgres, CouchDB, MiniO). To recover, restore one into the isolated Disaster Recovery slot and verify it before going live — restoring directly onto live Production is not allowed. Code and deployments are never touched.

Clone Create snapshot

Creating snapshot - Production 25%

Snapshotting postgres data...

Protected by BitSwan Bailey tomas.novak@meridianfoods.cz Share Logout

Production · snapshot captured from the live DB



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.13

Information backup. Backups are taken, retained and verifiable by restoration.

DORA
ART. 12(1)

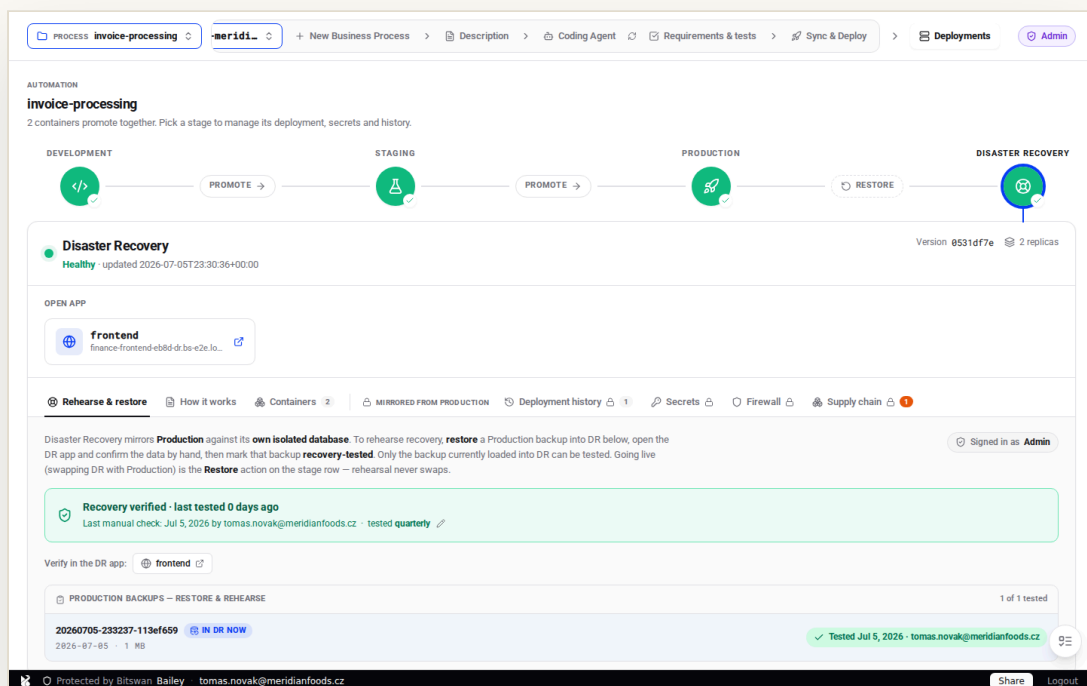
Backup policies and procedures. Scope and frequency are defined and enforced.

SOC 2
A1.2

Backup. Snapshots of live data are taken on demand and on policy.

Rehearse & restore (DR)

A backup you've never restored is a rumor. Bitswan makes the rehearsal a routine, the architecture legible, and the real cutover a single click.



Disaster Recovery · backup loaded into DR, recovery-tested

Restore a production backup **into the DR slot** — never onto live production. The restore streams its progress per store; when it lands, the slot is marked *In DR now*. Open it, confirm it's whole, and only the backup actually loaded into DR can be **marked recovery-tested**. The *How it works* tab explains the blue-green slots and the cutover in plain terms.

When you must go live, the **Restore** pill performs an ingress cutover — *Make Disaster Recovery the live Production?* — and -production repoints to the verified slot. No data migration, no redeploy, no downtime. (In a rehearsal you open that dialog to see it, then cancel.)

HOW TO

- 1 Take a production snapshot (Ch 15).
- 2 Go to **Disaster Recovery** → **Rehearse & restore**.
- 3 **Restore into DR**, verify, **Mark recovery-tested**.
- 4 Use the **Restore** pill to swap live when needed.

0 s

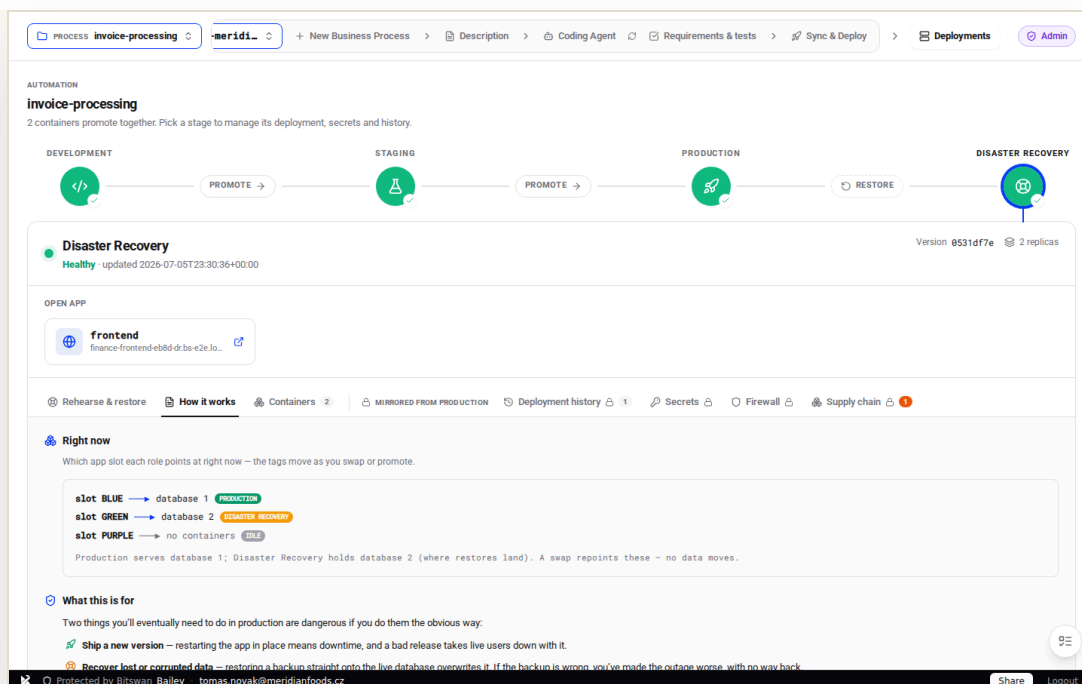
downtime on a swap

Quarterly

default test cadence

Verified

test only what's loaded



Disaster Recovery · how the blue-green slots and swap work



Bailey is best practice — what the standards ask of you, and how this does it

DORA

ART. 11–12

Response, recovery & restoration testing.

You must regularly test your ability to restore — here it's a routine, and the last pass is recorded.

SOC 2

A1.2 / A1.3

Backup & recovery testing.

Restores are rehearsed into an isolated DR slot and the test is recorded.

ISO/IEC 27001

A.5.30 / A.8.13

ICT readiness for continuity.

Backups are verified by restoration into an isolated slot.

NIS2

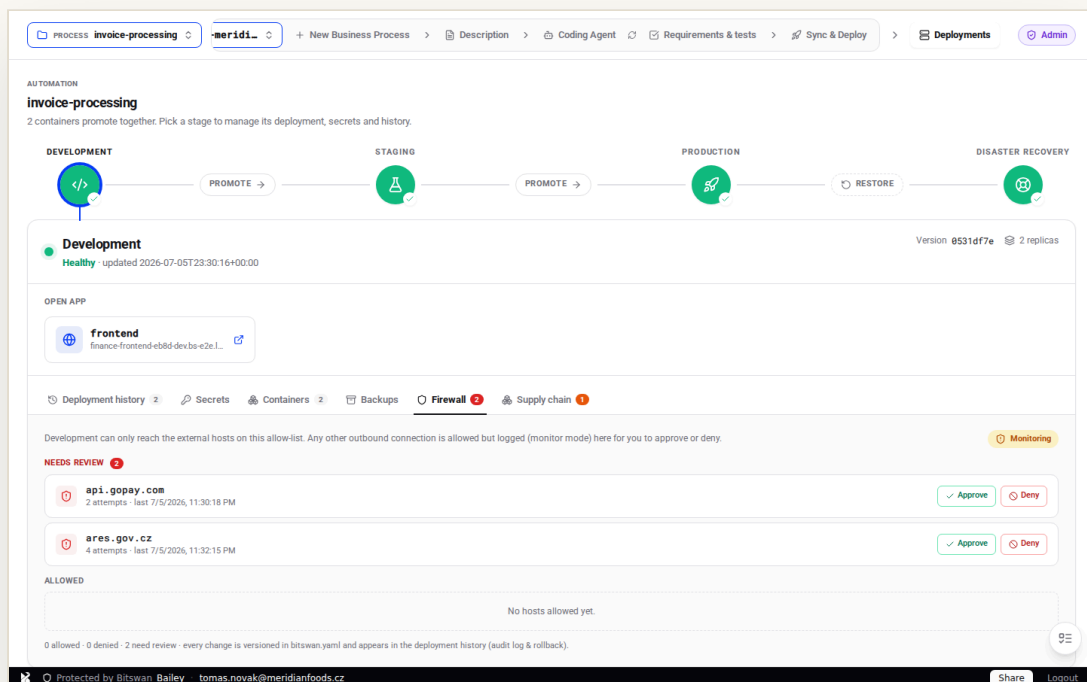
ART. 21(2)(C)

Business continuity & crisis management.

A zero-downtime swap means recovery doesn't cost an outage.

Firewall & data processing

An egress allow-list with a GDPR data-processing record for every external host — approval workflow, versioning and the DPA on file.



Firewall · the egress allow-list and its posture (Monitoring in dev, Enforcing in production)

Meridian's invoice flow really does reach out — on startup and on a loop it connects to its vendor portals, the Czech business register (`ares.gov.cz`, vendor VAT-ID checks) and the payment gateway. With an egress gateway watching a stage, the firewall reads the SNI/Host of every outbound connection: egress

is **default-deny** in staging and production; in dev it observes and surfaces each unlisted destination under **Needs review** for an operator to approve or deny.

Approving a host opens its **data-processing record**. The operator first answers whether any user/personal data is sent at all; if it is, the form asks *what* data leaves, *what it's used for*, whether it's *stored* there (No / Transient / Yes), the processor's *jurisdiction*, and takes the signed **Data Processing Agreement (PDF)**. Save the record and the host is allowed. So your Article 30 register and your Article 28 DPA file build themselves as the system is operated, instead of being reconstructed under audit pressure.

HOW TO

- 1 Open a stage → **Firewall** (wait for it to load the live posture).
- 2 Find the real outbound host under **Needs review** and press **Approve**.
- 3 Answer “No user data?”, or fill **what data / purpose / stored? / jurisdiction**.
- 4 Attach the processor's **DPA (PDF)** and press **Approve & record** — the host is recorded and allowed.

GDPR, BY CONSTRUCTION

Every external recipient of data is recorded with its purpose and contract at the moment it's allowed. The record of processing activities (Art. 30) and the processor agreements (Art. 28) are a by-product of running the system — not a spreadsheet someone keeps separately.

PROCESS invoice-processing

meridi...

+ New Business Process

Description

Coding Agent

Requirements & tests

Sync & Deploy

Deployments

Admin

AUTOMATION

invoice-processing

2 containers promote together. Pick a stage to manage its deployment

DEVELOPMENT

PROMOTE →

Development

Healthy · updated 2025-07-05T23:30:16+00:00

OPEN APP

frontend

finance-frontend-eb8d-dev.bs-e2e.L...

Deployment history

Secrets

Containers

Development can only reach the external hosts on this allow-list. Any

NEEDS REVIEW 2

api.gopay.com

2 attempts · last 7/5/2025, 11:30:18 PM

ares.gov.cz

4 attempts · last 7/5/2025, 11:32:15 PM

ALLOWED

No hosts allowed yet.

0 allowed · 0 denied · 2 need review · every change is versioned in bitawan.yaml and appears in the deployment history (audit log & rollback).

DISASTER RECOVERY

RESTORE

Version 0531df7e

2 replicas

Monitoring

Approve

Deny

Approve

Deny

Approve 3rd-party access

api.gopay.com

Development will be permitted to reach this host. GDPR requires documenting what data leaves the system and how the processor handles it – recorded in the audit log against your name.

☐ No user data is sent to this service
Tick if only non-personal/operational data leaves the system.

1 - What data is sent to the 3rd party

Vendor VAT-IDs and invoice totals for validation.

2 - What is the data used for

Validate vendor VAT-IDs against the Czech business register.

3 - Is the data stored there?

No

Transient

Yes

4 - Jurisdiction of the data processor

EU (Czech Republic)

5 - Data processing agreement (PDF)

Upload DPA PDF

Cancel

Approve & record

Protected by Bitswan Bailey

tomas.novak@meridianfoods.cz

Share

Logout

GDPR data-processing record · the Article 30 form an operator completes before egress is allowed



Bailey is best practice — what the standards ask of you, and how this does it

GDPR
ART. 30

Records of processing activities. Each external recipient is logged with its purpose and whether personal data is transferred — the register maintained automatically.

GDPR
ART. 28

Processor obligations. A Data Processing Agreement is stored on file for every host that processes personal data before egress is allowed.

NIS2
ART. 21(2)(A)

Risk-analysis & network security policies. Default-deny egress with reviewed, documented exceptions.

ISO/IEC 27001
A.8.20–8.21

Network & network-service security. Outbound connections are controlled per service.



Supply chain

A full software bill of materials for what you run — vulnerabilities ranked, advisories one click away, accepted risks recorded.

The screenshot shows the Meridian UI for the 'invoice-processing' automation. The top navigation bar includes 'PROCESS', 'invoice-processing', 'meridi...', '+ New Business Process', 'Description', 'Coding Agent', 'Requirements & tests', 'Sync & Deploy', 'Deployments', and 'Admin'. The main content area shows the 'Production' stage of the deployment pipeline, which is 'Healthy' and updated on 2025-07-05T23:30:36+00:00. Below this, the 'Supply chain' panel is active, displaying a table of packages and their vulnerabilities. The table has columns for 'PACKAGE', 'VERSION', and 'VULNERABILITIES'. The packages listed are 'undici', 'github.com/gohugoio/hugo', 'busybox', 'busybox-binsh', 'ssl_client', 'tar', and 'golang.org/x/sys'. Each package has one or more vulnerabilities listed, such as 'GHSA-35p6-xwp-9g52', 'GHSA-g8a3-5g58-fq7m', 'GHSA-p88a-4jf...', 'GHSA-c2xf-9v2r-r2rx', 'GHSA-c3wq-j5vh-68rc', 'GHSA-c54g-xjw...', 'GHSA-mcv8-8n8x-48pg', 'GHSA-q76j-gcg9-vxc6', 'GHSA-vxgm-5rre', 'CVE-2025-68876', 'GHSA-vnf3-w455-68vh', and 'GO-2026-5824'. An activity panel on the right shows recent events, including 'commit changes' and 'invoice-processing promoted'.

PACKAGE	VERSION	VULNERABILITIES
undici	6.26.0	GHSA-35p6-xwp-9g52, GHSA-g8a3-5g58-fq7m, GHSA-p88a-4jf...
github.com/gohugoio/hugo	v0.134.3	GHSA-c2xf-9v2r-r2rx, GHSA-c3wq-j5vh-68rc, GHSA-c54g-xjw...
busybox	1.37.0-r31	CVE-2025-68876
busybox-binsh	1.37.0-r31	CVE-2025-68876
ssl_client	1.37.0-r31	CVE-2025-68876
tar	7.5.15	GHSA-vnf3-w455-68vh
golang.org/x/sys	v0.25.0	GO-2026-5824

Supply chain · the SBOM/CVE panel for the deployed image

Every deployed image carries an SBOM. The **Supply chain** view ranks vulnerabilities by severity and shows the affected package; opening a CVE links straight to osv.dev, NVD and GitHub advisories so triage starts with the facts.

Out-of-scope decisions are explicit, attributable and stored in source — not a screenshot in someone's inbox. The scan runs on the image that

actually ships, so the picture is never stale.

HOW TO

- 1 Open a stage → **Supply chain.**
- 2 Sort by severity; open a CVE for its advisory.
- 3 Record any out-of-scope decision in-tree.

The screenshot shows the Bitwarden dashboard for the 'invoice-processing' business process. A modal window displays details for CVE-2025-68876, which is a Medium severity vulnerability in busybox. The modal includes links to 'osv.dev' and 'NVD' for more information. The background shows a deployment pipeline with stages: Development, Staging, Production, and Disaster Recovery. The Production stage is currently active, showing a healthy state. A table lists packages deployed to Production, including undici, github.com/gohugoio/hugo, busybox, busybox-binsh, ssl_client, tar, and golang.org/x/sys. The busybox package is highlighted with a yellow warning icon and the CVE-2025-68876 advisory. The bottom of the dashboard shows a footer with 'Protected by Bitwarden Bailey tomas.novak@meridianfoods.cz' and a 'Share' button.

Production
Healthy updated 2026-07-05T23:30:36+00:00

Deployment history 1 Secrets Containers 2

Packages in the images deployed to Production and known vulnerabilities (3)

PACKAGE	Version	Known Vulnerabilities
undici	v8.134.3	GHSA-mcv8-8n8x-48pg, GHSA-q76j-gcg9-vxc6, GHSA-vxgm-5rm
github.com/gohugoio/hugo	v8.134.3	GHSA-mcv8-8n8x-48pg, GHSA-q76j-gcg9-vxc6, GHSA-vxgm-5rm
busybox	1.37.0-r31	CVE-2025-68876
busybox-binsh	1.37.0-r31	CVE-2025-68876
ssl_client	1.37.0-r31	CVE-2025-68876
tar	7.5.15	GHSA-vaf3-w455-68vh
golang.org/x/sys	v0.25.0	GO-2025-5824

363 packages · 17 in-scope CVEs · scanned 7/5/2026, 11:29:48 PM

Protected by Bitwarden Bailey tomas.novak@meridianfoods.cz

Share Logout

CVE advisory detail · severity, CVSS score and description — what the operator triages before waiving or patching



Bailey is best practice — what the standards ask of you, and how this does it

NIS2

ART. 21(2)(D)

Supply-chain security. You can produce, on demand, exactly what is inside what you run.

SOC 2

CC7.1

Vulnerability detection. The SBOM and CVE scan run on the image that actually ships.

ISO/IEC 27001

A.5.7 / A.8.8

Threat intelligence & vulnerability management. Continuous visibility of known vulnerabilities in your dependencies.



People & roles

A roster with explicit roles — operator, auditor, member — and per-person trusted devices you can approve or revoke.

bailey-onboard.bs-e2...
Bailey Server

WORKSPACE

- Workspaces
- Handbook

YOUR ACCOUNT

- Your devices
- Security & recovery

ADMIN

- Server overview
- Resource management
- People & roles**
- Endpoint access

People & roles

Everyone with access to this server. Roles govern what they can do; devices govern where they can do it from. New sign-ins from an untrusted device appear here for you to approve.

☐ Least-trust access: a role grants *capabilities*, never blanket data access. Even an admin only reaches workspaces they created or were granted — so each person controls who sees their own data.

ADMIN
 Manages users, server settings, and device approvals. Still sees only workspaces they own or were granted — not everyone's.

AUDITOR
 Reviews security activity and signs off on deploy promotions. No automatic access to others' workspace data.

MEMBER
 Builds in workspaces they own or were added to.

USER
 A signed-in identity with no elevated role; sees only workspaces they own or are added to.

Search people... [Invite person](#)

PERSON	ROLE	WORKSPACES	DEVICES	LAST ACTIVE
tomas.novak@meridianfoods.cz tomas.novak@meridianfoods.cz	ADMIN	0	1	7/5/2026, 11:19:22 PM

Workspace "finance" created

People & roles · the Meridian Foods roster

Tomáš operates (admin), Eva audits, Marek and the team build (members). Roles are resolved from Bailey's own user-role store and enforced **server-side** — not merely hidden in the UI. This is also where pending devices are approved and lost ones revoked.

The **auditor** role is not simply read-only. An auditor reviews everything *and* holds the **governance** controls a compliance owner needs: they can set the recovery-test cadence and

approve a production egress host's data-processing record. What they cannot do is operate the pipeline — no deploying or promoting code, no managing people, roles or devices, no touching the server's admin settings. A **member** does the day-to-day build/ship work but cannot change governance settings; an **admin** holds everything. That split is the segregation of duties an auditor signs off on — the person who sets the recovery cadence and vets a new data recipient is deliberately *not* the person who ships the code.

HOW TO

- 1 Open **People & roles** in the console.
- 2 Review roles across the team.
- 3 Approve a pending device by its code.
- 4 Revoke a device or change a role as people join and leave.

WHAT AN AUDITOR CAN ACTUALLY DO

An auditor is read-only on the *operational* pipeline (no deploy, promote, people/role or device management, no server admin) but holds the *governance* controls: setting the recovery-test cadence and approving a production egress host's GDPR data-processing record. Oversight with authority over compliance settings — deliberately separated from the authority to ship code.



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.5.18 / A.5.3

Access rights & segregation of duties.

Admin, auditor and member are distinct, server-enforced roles: the auditor's governance authority is separated from the member's build/ship authority.

SOC 2

CC6.2 / CC6.3

Access provisioning & de-provisioning.

Roles and per-person trusted devices are granted and revoked centrally.

NIS2

ART. 21(2)(I)

Human-resources security & access control.

Access is role-based and reviewable.

DORA

ART. 9(4)

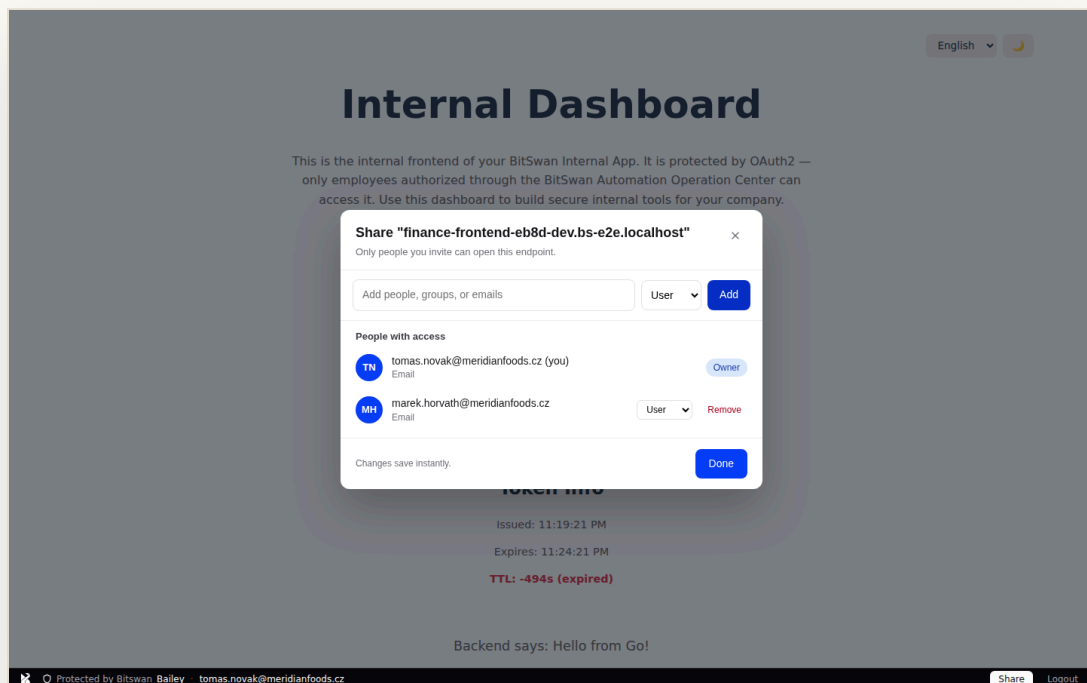
Access management on a need-to-know

basis. Each role gets only the rights its duties require — auditors hold governance (recovery cadence, processing-record approval) but not deploy/promote; members ship but cannot change governance settings.



Sharing an endpoint

Every protected app the gate fronts — including the frontends your operators build and deploy — can be shared, by its owner, with named people or groups, at view or owner level, without touching anyone else's access.



Share endpoint · sharing a deployed automation's own frontend (a Bailey-protected endpoint) with a teammate at User level

Access is deny-by-default: only people you invite can open an endpoint. Crucially, this is not just the dashboard — the **frontend Meridian's invoice-processing automation deploys is itself a Bailey-protected endpoint**. Open that frontend and Bailey's own chrome wraps it, with a **Share** button

for its owner. From there the owner grants access to a person (by email) or a whole identity-provider group, choosing *User* (open and use it) or *Owner* (also manage who else can). Grants are recorded with who granted them and when, and a user who hits a wall can *request access*, which surfaces to the owner to approve or deny — so access is a deliberate decision with a trail, not a shared password.

The same mechanism fronts everything: a workspace dashboard, gitops, and every automation frontend an operator creates. Adding a member to the Meridian Foods workspace is a grant on the workspace's endpoint; letting a teammate into a deployed invoice app is a grant on that app's endpoint. Because every grant is per-endpoint and owner-managed, there is no god-mode admin quietly reading everything — least privilege is the default, and revoking is as immediate as granting.

HOW TO

- 1 Open a deployed automation's **frontend** (it's a Bailey-protected endpoint); click **Share** in its chrome.
- 2 Type a person's email (or a /group); pick **User** or **Owner**.
- 3 Press **Add** — access is effective immediately and recorded.
- 4 Approve or deny any pending access requests; **Remove** to revoke.

WHY IT MATTERS

Sharing is per-endpoint, owner-driven and recorded. Access control isn't a central list someone forgets to prune — it's the owner of each app deciding, in the open, exactly who can reach it, and revoking the instant they shouldn't.



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.5.15 / A.8.3

Access control & information access

restriction. Access to each endpoint is granted explicitly, per principal, by its owner.

SOC 2

CC6.1 / CC6.3

Logical access & role-based access.

Endpoints are deny-by-default; grants carry a role and an attributable grantor.

NIS2

ART. 21(2)(I)

Access control. Who can reach which service is explicit, owner-managed and revocable.

GDPR

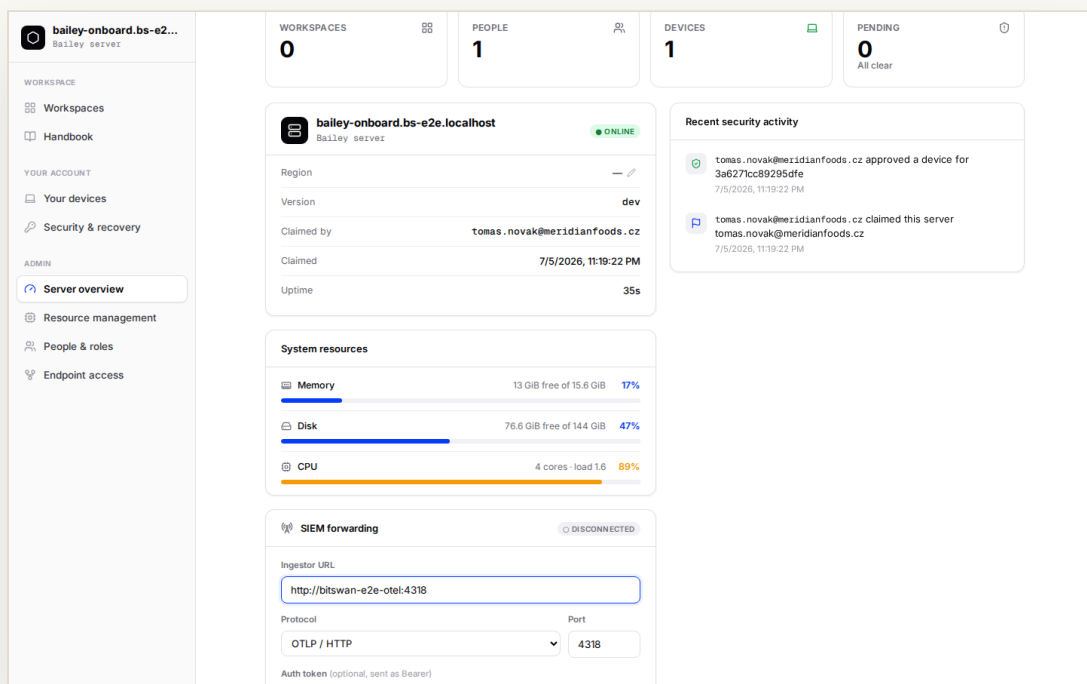
ART. 5(1)(F) / ART. 32

Integrity & confidentiality. Personal data behind an endpoint is reachable only by explicitly granted principals.



SIEM export & monitoring

Stream the server's security audit log — access approvals, role and device changes, workspace events — to your SIEM over OpenTelemetry, as it happens.



SIEM forwarding · the config form — the OTLP endpoint base URL and the protocol, filled in before Save & connect

Bailey keeps its own security audit trail, but your SOC wants everything in one place. The **SIEM forwarding** card (Server overview) points Bailey at an external **OpenTelemetry** ingestor and mirrors every security event there in real time: device-trust changes, role changes, workspace creation, access approvals.

You give it two things. The **Ingestor URL** is your collector's **OTLP base URL** — just the host (and port), e.g. `https://collector.example.com`; Bailey appends the `/v1/logs` path itself, so you never spell out the signal path. The **Protocol** picks how the logs are framed: **OTLP/HTTP** (protobuf over HTTPS, the simplest to route through a proxy) or **OTLP/gRPC** (a streaming gRPC channel, lower-overhead at volume) — match whichever your collector listens on. An optional bearer *Auth token* authenticates the stream.

Press **Save & connect** and Bailey runs a live connectivity test, so you see *Connected* (or the exact error) before you rely on it, and the card then shows when the last event was delivered. This is how Bailey's audit story plugs into the monitoring and detection your standards expect: the events exist regardless, and the export makes them available to correlation, alerting and long-term retention in the system your analysts already watch.

HOW TO

- 1 Open **Server overview**; find **SIEM forwarding**.
- 2 Click **Configure ingestor**; enter the **Ingestor URL**, pick the **Protocol**, add an **Auth token** if needed.
- 3 Press **Save & connect** — it tests the connection and shows *Connected* or the error.
- 4 Watch the live status and last-delivered time; **Edit** or **Disable** as needed.

MONITORING, WHERE YOU ALREADY LOOK

The audit events are produced no matter what; SIEM export simply forwards them, live, into your existing detection and retention pipeline — so monitoring and alerting happen in the tool your team already runs, not in a console they have to remember to open.

The screenshot displays the BitSwan Bailey server management interface. On the left is a sidebar with navigation links: WORKSPACE (Workspaces, Handbook), YOUR ACCOUNT (Your devices, Security & recovery), and ADMIN (Server overview, Resource management, People & roles, Endpoint access). The main content area is titled 'bailey-onboard.bs-e2e.localhost' and shows the server is 'ONLINE'. It includes a metadata section with fields for Region, Version (dev), Claimed by (tomas.novak@meridianfoods.cz), Claimed (7/5/2026, 11:19:22 PM), and Uptime (35s). Below this is a 'System resources' section with progress bars for Memory (13 GiB free of 15.6 GiB, 17%), Disk (76.6 GiB free of 144 GiB, 47%), and CPU (4 cores - load 1.6, 89%). The 'SIEM forwarding' section shows a 'CONNECTED' status, a description of streaming audit logs to a SIEM via OpenTelemetry (OTLP), the endpoint 'http://bitswan-e2e-otel:4318:4318', and the last delivery time '7/5/2026, 11:19:33 PM'. A 'Recent security activity' panel on the right lists two events: a device approval and a server claim, both by tomas.novak@meridianfoods.cz. A bottom notification bar states 'SIEM forwarding connected'.

SIEM forwarding · connected — the connectivity test passed; the same audit events, forwarded live



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.15 / A.8.16

Logging & monitoring. Security events are exportable, in real time, to centralized monitoring and retention.

SOC 2
CC7.2

System monitoring. Audit events feed an external SIEM for correlation and alerting.

DORA
ART. 10

Detection of anomalous activities. Real-time event export enables continuous detection in your SOC.

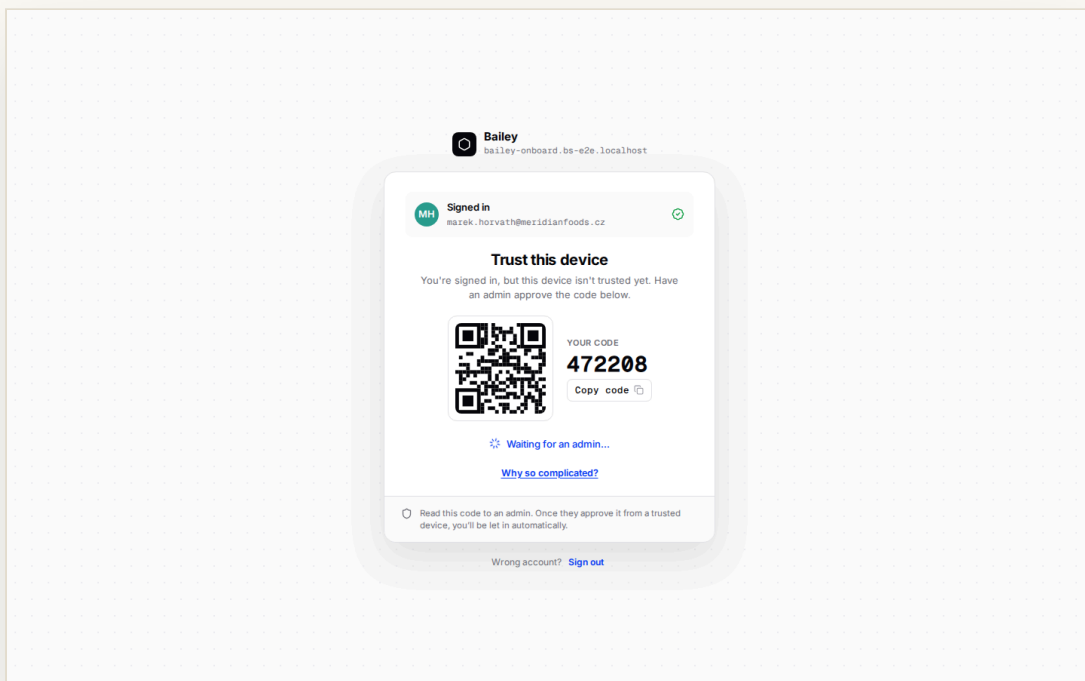
NIS2
ART. 21(2)(B)

Incident handling. Centralized, exported events shorten detection and support reconstruction.



A teammate's first login

A new teammate signs in through your identity provider from their own laptop — and gets nothing. Identity alone is not access: Bailey is deny-by-default, and an unknown device waits at the gate.



New device · Marek is signed in, but the device isn't trusted — a 6-digit code and “Waiting for an admin...”

Marek Horváth joins Meridian as a process developer. He opens Bailey on his own laptop and signs in with his Meridian identity — a perfectly valid login. He still sees **none of the product**. Instead the gate stops him with “*Trust this device*”: “You’re signed in, but this device isn’t trusted yet.” His browser shows a large **6-**

digit code labelled “*Your code*”, the prompt to “*Read this code to an admin*”, and a spinner: “*Waiting for an admin...*”

This is **deny-by-default** made concrete. A leaked or phished password is not enough to reach anything, because access is bound to *this hardware*, not just the credential — and this hardware is unknown. The code is a **presence proof**: an admin will only let the device in after Marek reads them the number off his own screen, so a stolen identity-provider account on an attacker’s machine never clears the gate. Nothing — no workspace, no app, no console — is reachable until someone who already holds trust says yes.

HOW TO

- 1 A new teammate signs in at the Bailey host on their own device.
- 2 The gate shows **Trust this device** — they are signed in but not trusted.
- 3 Their device displays a **6-digit code** and waits.
- 4 Nothing in the product is reachable until an admin approves the device.

WHY IT MATTERS

A valid login is not access. By binding trust to the device and requiring a present, trusted admin to admit it, a stolen password — or a whole compromised identity-provider account — still reaches nothing on its own.



Bailey is best practice — what the standards ask of you, and how this does it

NIS2

ART. 21(2)(J)

Multi-factor authentication & secured access. Device trust is a hardware-bound second factor; identity alone never grants access.

ISO/IEC 27001

A.5.15 / A.8.5

Access control & secure authentication. Access is deny-by-default and granted per device, not per credential.

SOC 2

CC6.1

Logical access security. A new principal is denied at the gate until explicitly authorized.

DORA

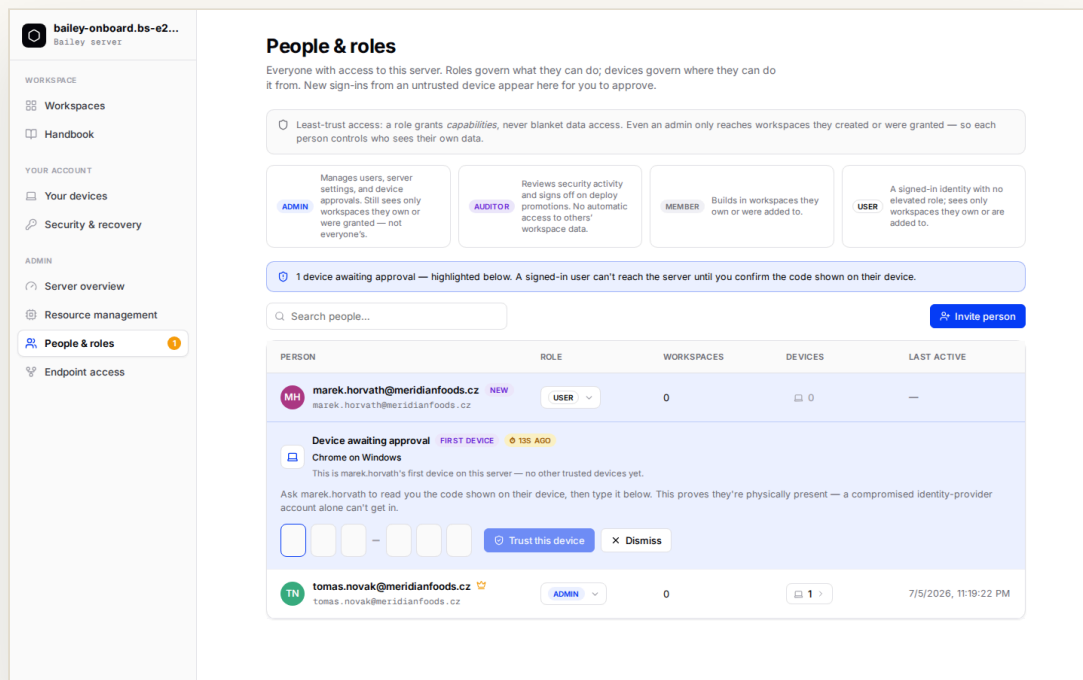
ART. 9(3)

Strong authentication mechanisms. Robust access control gates every new device before it reaches a system.



Approve the person & trust the device

Approval is a deliberate, present-tense act. The admin sees the pending device in People & roles, confirms the person is really there by the code on their screen, and trusts the device — admitting the user in one move.



People & roles · Marek's "Device awaiting approval" bar — the admin types the code from his screen

Back in the Server Console, Tomáš opens **People & roles**. Marek's request surfaces inline, under his name, as a *"Device awaiting approval"* bar — badged *First device*, with how long it's been waiting. The prompt is explicit: *ask Marek to read you the code shown on his device*,

then type it below. The code is never sent to the admin by the server — that is the whole point. Tomáš must hear it from Marek (in person, on a call), which proves Marek is physically present at that device.

Tomáš types the six digits and presses **Trust this device**. In one action this **enrols the user and trusts the device**: Marek becomes a real device owner and his laptop is now a trusted device, badged and revocable like any other (Ch 04). The request clears. There is no quiet auto-admit and no “deny” to forget about — unapproved devices simply expire. Who gets in, and on which hardware, is a decision a trusted admin makes in the open, with a presence check — exactly the control an auditor wants to see.

HOW TO

- 1 Open **People & roles** in the console.
- 2 Find the teammate's **Device awaiting approval** bar.
- 3 Ask them to read you the **6-digit code** on their screen; type it in.
- 4 Press **Trust this device** — the person is enrolled and the device trusted.

A PRESENCE CHECK, NOT A RUBBER STAMP

The server never reveals the code to the approver — the admin has to get it from the person, in real time. That converts “approve a request” into “confirm a present, identified human on a specific device”, so a remote attacker holding only stolen credentials can't be approved.

bailey-onboard.bs-e2...

bailey server

WORKSPACE

Workspaces

Handbook

YOUR ACCOUNT

Your devices

Security & recovery

ADMIN

Server overview

Resource management

People & roles

Endpoint access

People & roles

Everyone with access to this server. Roles govern what they can do; devices govern where they can do it from. New sign-ins from an untrusted device appear here for you to approve.

Least-trust access: a role grants *capabilities*, never blanket data access. Even an admin only reaches workspaces they created or were granted — so each person controls who sees their own data.

ADMIN

Manages users, server settings, and device approvals. Still sees only workspaces they own or were granted — not everyone's.

AUDITOR

Reviews security activity and signs off on deploy promotions. No automatic access to others' workspace data.

MEMBER

Builds in workspaces they own or were added to.

USER

A signed-in identity with no elevated role; sees only workspaces they own or are added to.

Q Search people...

Invite person

PERSON	ROLE	WORKSPACES	DEVICES	LAST ACTIVE
TR tomas.novak@meridianfoods.cz tomas.novak@meridianfoods.cz	ADMIN	1	1	7/5/2026, 11:33:02 PM

Device trusted for marek.horvath@meridianfoods.cz

People & roles · the device trusted, the pending request cleared



Bailey is best practice — what the standards ask of you, and how this does it

SOC 2

CC6.2 / CC6.3

Access provisioning. A new principal and device are granted access centrally, by an authorized admin, with a presence check.

ISO/IEC 27001

A.5.16 / A.5.18

Identity & access-rights management.

Enrolment of a user and device is an explicit, authorized, recorded act.

NIS2

ART. 21(2)(J)

Secured access. Device trust is admitted only by an already-trusted admin, with out-of-band code confirmation.

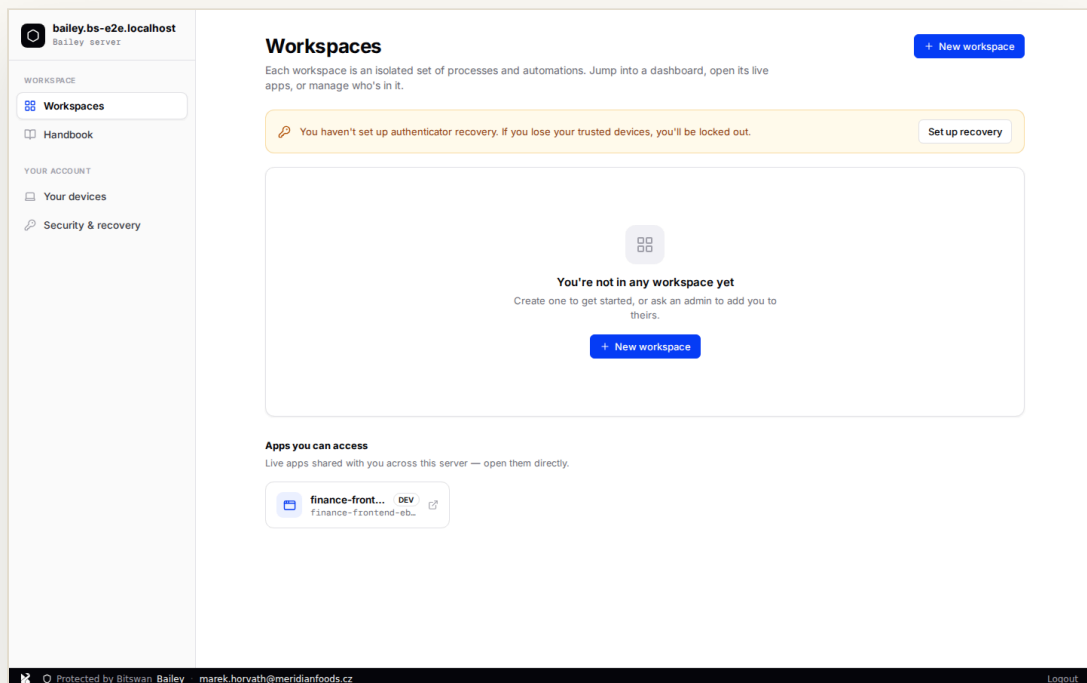
DORA

ART. 9(4)

Access on a need-to-know basis. Access is conferred deliberately by an admin, not assumed from a login.

Access granted

The moment the admin trusts it, the teammate's device is let through — no re-login, no second step. And the same console that admitted the device is where you cut it, the instant a laptop is lost or a person leaves.



New device · approved and redirected through the gate — access now granted on Marek's laptop

Marek's laptop never stopped waiting at the gate. The instant Tomáš trusts the device, the gate clears it — Marek's screen leaves the “*Waiting for an admin...*” state and he lands on exactly what he was reaching for. From now on his device carries its own trust cookie: he comes and goes without re-approval, alongside the

operator, each on their own trusted hardware.

Crucially, trust is **per-device and reversible from one place**. Marek's laptop now appears in the roster like any other trusted device — and the same People & roles / Your devices surface that admitted it is where you **remove** it. If that laptop is lost or stolen, or Marek leaves Meridian, you don't scramble to rotate passwords across a dozen apps: you find the device (or the person) and revoke it, and its access to the console and every workspace app is gone instantly (Ch 04). Onboarding and offboarding are the same lever, pulled in opposite directions — admit a device to let someone in, cut a device to lock a stolen laptop or a departing employee out.

HOW TO

- 1 The teammate's device, still waiting, is admitted the moment it's trusted.
- 2 It redirects straight into what they were granted — no re-login.
- 3 The device now appears in the roster, badged and revocable.
- 4 **Lost device or leaver?** Remove the device (or person) here — access is revoked everywhere, instantly.

ONBOARDING AND OFFBOARDING ARE ONE LEVER

Admitting a device and revoking it are the same control. A stolen laptop or a departing employee isn't a password-reset fire drill — it's one click to remove the device, and its access to the console and every workspace app ends immediately.



Bailey is best practice — what the standards ask of you, and how this does it

SOC 2

CC6.2 / CC6.3

Access provisioning & de-provisioning. A device is admitted and, just as immediately, revocable centrally when lost or on a leaver.

ISO/IEC 27001

A.5.15 / A.8.1

Access control & user-endpoint devices.

Per-device trust is granted, badged and revoked from one place.

NIS2

ART. 21(2)(J)

Secured access. Hardware-bound trust is admitted and revoked per device and per person.

DORA

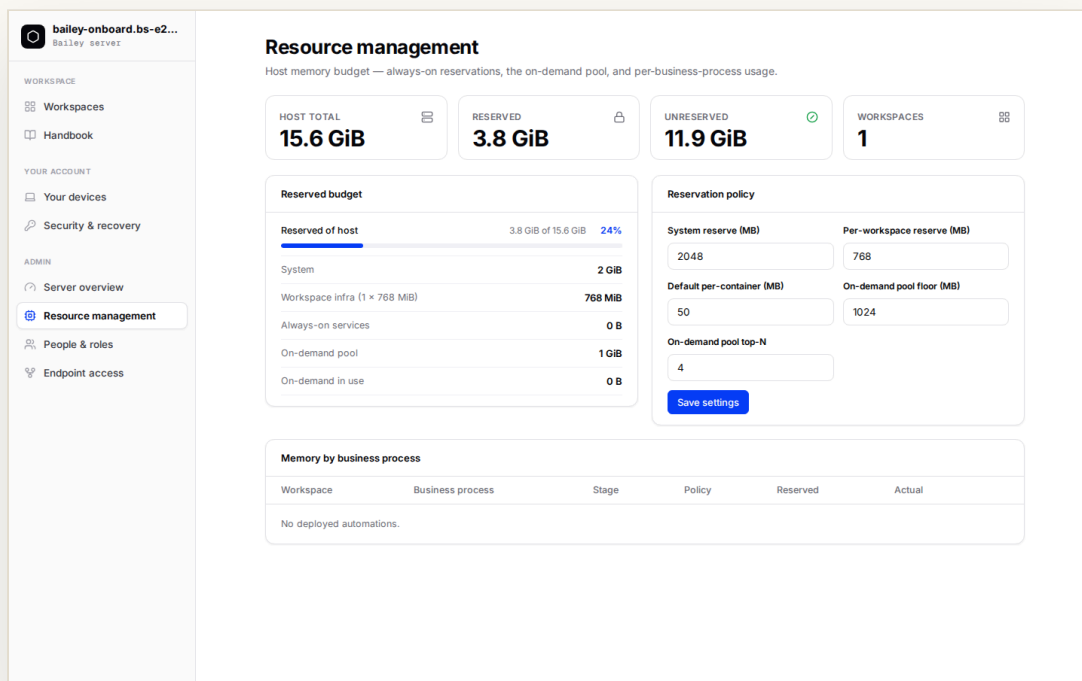
ART. 9

Protection & prevention. Immediate device revocation contains a lost device or a departing insider.



Memory governance & the on-demand pool

Users spin up as many previews and processes as they like without starving the workloads that matter. Bailey reserves memory for the services that must stay up and lets everything else scale to zero under pressure — waking on demand the moment someone touches it.



Server Console · Resource management — the memory budget, reserved breakdown and per-business-process usage

Every automation declares two things in `automation.toml`: a **memory-reservation** (how much it is budgeted, in MB) and a **memory_reservation_policy** — *always-on* for a backend that must

never stop (it runs background work), or *on-demand* (the default) for everything that can be paused when idle and woken on access. The daemon reads these off the running containers and keeps a single, honest budget: host memory, minus a system reserve, minus a per-workspace infrastructure reserve, minus every always-on reservation, minus a sized **on-demand pool**.

That pool is the trick that lets users keep *unlimited* rarely-used business processes without cost. It is sized to run the largest few on-demand services at once and grows only when someone deploys a genuinely large one — so small, idle processes never consume reserved memory. When the running on-demand set exceeds the pool, Bailey shuts down the least-recently-used ones; the next time a person opens one, a loading screen appears and it is back in seconds. Promotions and new workspaces that would not fit the reserved budget are

refused up front, with a message that says exactly how much is short. And any container that outgrows its reservation raises a SIEM event and is flagged, in red, right on its Containers tab.

HOW TO

- 1 Declare **memory-reservation** (and, for a background worker, **memory_reservation_policy = "always-on"**) in `automation.toml`.
- 2 Open **Resource management** in the Server Console to see the host budget, the reserved breakdown and per-process usage.
- 3 Promote or create a workspace — Bailey admits it only if it fits the reserved budget, else tells you the shortfall.
- 4 Leave idle previews alone: they are shut down under pressure and **wake automatically** when next accessed.
- 5 Watch for the red **over-reservation** flag on the Containers tab — it also lands in your SIEM feed.

RESERVE WHAT MATTERS; EVICT THE REST

Always-on backends are guaranteed their memory; everything else lives in a bounded pool that scales to zero and wakes on demand. A busy workspace full of experiments can never starve production.

The screenshot displays the Workspace dashboard for a business process named 'invoice-processing'. At the top, there's a navigation bar with tabs for 'PROCESS', 'DESCRIPTION', 'CODING AGENT', 'REQUIREMENTS & TESTS', 'SYNC & DEPLOY', 'DEPLOYMENTS', and 'ADMIN'. Below this, the 'AUTOMATION' section shows a deployment pipeline with stages: DEVELOPMENT, STAGING, PRODUCTION, and DISASTER RECOVERY. The current deployment is 'Development' (version 1ca86279) with 2 replicas, showing a 'Healthy' status. Below the pipeline, there's a section for 'OPEN APP' showing 'frontend'. A 'Deployment history' table lists previous deployments, with the current one highlighted. An 'Activity' sidebar on the right shows recent events like 'apply template', 'invoice-processing ready', 'commit changes', and 'invoice-processing synced an...'. The bottom of the dashboard includes a footer with 'Protected by BitSwan Bailey' and user information.

Workspace dashboard · a business process's containers, each showing live memory against its reservation



Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001

A.8.6

Capacity management. Memory is reserved, budgeted and admission-controlled from live host state; over-use is detected and alerted.

SOC 2

A1.1

Availability. Critical (always-on) workloads keep their reserved capacity; non-critical ones are shed under pressure without losing their state.

NIS2

ART. 21(2)(C)

Business continuity & capacity. Resource pressure is managed automatically so essential services stay available.

DORA

ART. 9

Performance & capacity. ICT resource limits are governed and monitored, with alerts when a workload exceeds its budget.



Standards → features

One page for your auditor: the controls ISO 27001, SOC 2, DORA, NIS2 and GDPR ask for, and the Bitswan feature that delivers each.

STANDARD & CLAUSE	WHAT IT ASKS OF YOU	DELIVERED BY
NIS2 Art. 21(2)(j)	Multi-factor authentication & secured access. Device trust is a strong second factor bound to hardware — exactly the “MFA or continuous authentication” the directive expects.	Claim & device trust
SOC 2 CC6.1	Logical access security. The gate authenticates and authorizes every request before it reaches a workspace app.	Claim & device trust
ISO/IEC 27001 A.5.15 / A.8.5	Access control & secure authentication. Access is granted per identity and per device, and centrally revocable.	Claim & device trust
DORA Art. 9(3)	Strong authentication mechanisms. Protection of ICT systems requires robust access control — the gate provides it uniformly.	Claim & device trust
ISO/IEC 27001 A.8.3 / A.5.15	Information access restriction & access control. A workspace scopes who can reach its processes and data; access is granted per workspace.	Workspaces

SOC 2 CC6.3	Role-based access. Membership and roles are assigned per workspace and enforced server-side.	Workspaces
NIS2 Art. 21(2)(i)	Asset management & access control. Every workspace and its endpoints are inventoried and owned.	Workspaces
ISO/IEC 27001 A.5.9	Inventory of information and other associated assets. Every workspace and protected endpoint is enumerated from real, live state.	Server overview & endpoints
NIS2 Art. 21(2)(i)	Asset management. The estate of exposed services is inventoried with ownership.	Server overview & endpoints
SOC 2 CC6.1	Logical access security. Each endpoint sits behind the gate with an explicit owner.	Server overview & endpoints
SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. Devices are granted and revoked centrally and immediately.	Your devices
ISO/IEC 27001 A.5.15 / A.8.1	Access control & user-endpoint devices. Trusted devices are enrolled, labelled and revocable.	Your devices
NIS2 Art. 21(2)(j)	Secured access. Hardware-bound trust is enrolled and managed per person.	Your devices
ISO/IEC 27001 A.8.31	Separation of development, test and production. A personal copy isolates work-in-progress from main and from deployed stages.	The workspace & copies
SOC 2 CC8.1	Change management. Changes originate in an isolated copy and reach main only through Sync & Deploy.	The workspace & copies

ISO/IEC 27001 A.5.9	Inventory of assets. Each business process is a named, owned unit of the estate.	Business processes
ISO/IEC 27001 A.8.25	Secure development lifecycle. Work is organised per process, with its own pipeline and controls.	Business processes
ISO/IEC 27001 A.5.37	Documented operating procedures. The process and its rules are written down and kept current alongside the code.	Describe the process
ISO/IEC 27001 A.8.25 / A.8.31	Secure development lifecycle & environment separation. The agent builds in an isolated copy/sandbox, never touching production directly.	Coding Agent & requirements
NIS2 Art. 21(2) (e)	Security in development. Agent output is CVE-scanned and reviewed before deploy.	Coding Agent & requirements
SOC 2 CC6.6	Boundary protection. The agent's egress is constrained by the workspace firewall allow-list.	Coding Agent & requirements
DORA Art. 24–26	Resilience testing. Requirements are runnable specifications, re-run on demand.	Coding Agent & requirements
ISO/IEC 27001 A.8.31	Separation of development, test and production environments. Dev, staging and production each run on their own database, file store and Docker network — the stages cannot reach one another and production data is never present in a test stage.	Dev, staging & production
SOC 2 CC8.1	Change management. Changes are built and tested in lower stages and reach production only through a deliberate, reviewable promotion.	Dev, staging & production

GDPR Art. 5(1)(c)	Data minimisation. Real personal data lives only in production; dev and staging are tested without using production user data.	Dev, staging & production
ISO/IEC 27001 A.8.8	Management of technical vulnerabilities. The image is CVE-scanned before it ships, with each finding linked to its advisory.	Sync & Deploy
NIS2 Art. 21(2)(e)	Security in acquisition, development and maintenance, incl. vulnerability handling. Waivers are versioned in-tree and reviewable.	Sync & Deploy
DORA Art. 8–9	ICT risk identification & protection. Pre-deploy scanning makes risk identification automatic and auditable.	Sync & Deploy
SOC 2 CC8.1	Change management. Commit, rebase, deploy is one controlled, observable operation.	Sync & Deploy
ISO/IEC 27001 A.8.32	Change management. Production changes follow a controlled, reversible promotion path.	Blue-green production
ISO/IEC 27001 A.8.31	Separation of development, test and production. The dev / staging / production stages keep environments cleanly separated within a process.	Blue-green production
DORA Art. 9	Protection & prevention. Minimise the impact of changes on the availability of critical functions.	Blue-green production
ISO/IEC 27001 A.8.15	Logging (integrity & tamper-protection). Operational events are recorded on a fast-forward-only protected main — append-only and rewrite-proof, so the log is protected from tampering by construction, including by the operator.	Deployment history & inspect

DORA Art. 13	Learning and evolving. A complete record supports post-incident review.	Deployment history & inspect
NIS2 Art. 21(2)(b)	Incident handling. Reconstruct exactly what happened from the audit trail.	Deployment history & inspect
SOC 2 CC8.1	Change management. Every change is recorded with its diff and the config in force.	Deployment history & inspect
ISO/IEC 27001 A.8.24	Use of cryptography & secret management. Secrets are stored and injected securely, separated from source.	Secrets
NIS2 Art. 21(2)(h)	Cryptography and, where appropriate, encryption. Sensitive material is handled as such by default.	Secrets
GDPR Art. 32	Security of processing. Credentials that protect personal data are kept out of source and role-gated.	Secrets
SOC 2 CC7.2	System monitoring. Container health is visible per service, per stage.	Containers
DORA Art. 10	Detection. Operators can observe the live state of every running service.	Containers
ISO/IEC 27001 A.8.16	Monitoring activities. The running estate is observable in real time.	Containers
ISO/IEC 27001 A.8.13	Information backup. Backups are taken, retained and verifiable by restoration.	Backups & retention
DORA Art. 12(1)	Backup policies and procedures. Scope and frequency are defined and enforced.	Backups & retention

SOC 2 A1.2	Backup. Snapshots of live data are taken on demand and on policy.	Backups & retention
DORA Art. 11–12	Response, recovery & restoration testing. You must regularly test your ability to restore — here it's a routine, and the last pass is recorded.	Rehearse & restore (DR)
SOC 2 A1.2 / A1.3	Backup & recovery testing. Restores are rehearsed into an isolated DR slot and the test is recorded.	Rehearse & restore (DR)
ISO/IEC 27001 A.5.30 / A.8.13	ICT readiness for continuity. Backups are verified by restoration into an isolated slot.	Rehearse & restore (DR)
NIS2 Art. 21(2) (c)	Business continuity & crisis management. A zero-downtime swap means recovery doesn't cost an outage.	Rehearse & restore (DR)
GDPR Art. 30	Records of processing activities. Each external recipient is logged with its purpose and whether personal data is transferred — the register maintained automatically.	Firewall & data processing
GDPR Art. 28	Processor obligations. A Data Processing Agreement is stored on file for every host that processes personal data before egress is allowed.	Firewall & data processing
NIS2 Art. 21(2) (a)	Risk-analysis & network security policies. Default-deny egress with reviewed, documented exceptions.	Firewall & data processing
ISO/IEC 27001 A.8.20– 8.21	Network & network-service security. Outbound connections are controlled per service.	Firewall & data processing

NIS2 Art. 21(2) (d)	Supply-chain security. You can produce, on demand, exactly what is inside what you run.	Supply chain
SOC 2 CC7.1	Vulnerability detection. The SBOM and CVE scan run on the image that actually ships.	Supply chain
ISO/IEC 27001 A.5.7 / A.8.8	Threat intelligence & vulnerability management. Continuous visibility of known vulnerabilities in your dependencies.	Supply chain
ISO/IEC 27001 A.5.18 / A.5.3	Access rights & segregation of duties. Admin, auditor and member are distinct, server-enforced roles: the auditor's governance authority is separated from the member's build/ship authority.	People & roles
SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. Roles and per-person trusted devices are granted and revoked centrally.	People & roles
NIS2 Art. 21(2) (i)	Human-resources security & access control. Access is role-based and reviewable.	People & roles
DORA Art. 9(4)	Access management on a need-to-know basis. Each role gets only the rights its duties require — auditors hold governance (recovery cadence, processing-record approval) but not deploy/promote; members ship but cannot change governance settings.	People & roles
ISO/IEC 27001 A.5.15 / A.8.3	Access control & information access restriction. Access to each endpoint is granted explicitly, per principal, by its owner.	Sharing an endpoint
SOC 2 CC6.1 / CC6.3	Logical access & role-based access. Endpoints are deny-by-default; grants carry a role and an attributable grantor.	Sharing an endpoint

NIS2 Art. 21(2)(i)	Access control. Who can reach which service is explicit, owner-managed and revocable.	Sharing an endpoint
GDPR Art. 5(1)(f) / Art. 32	Integrity & confidentiality. Personal data behind an endpoint is reachable only by explicitly granted principals.	Sharing an endpoint
ISO/IEC 27001 A.8.15 / A.8.16	Logging & monitoring. Security events are exportable, in real time, to centralized monitoring and retention.	SIEM export & monitoring
SOC 2 CC7.2	System monitoring. Audit events feed an external SIEM for correlation and alerting.	SIEM export & monitoring
DORA Art. 10	Detection of anomalous activities. Real-time event export enables continuous detection in your SOC.	SIEM export & monitoring
NIS2 Art. 21(2)(b)	Incident handling. Centralized, exported events shorten detection and support reconstruction.	SIEM export & monitoring
NIS2 Art. 21(2)(j)	Multi-factor authentication & secured access. Device trust is a hardware-bound second factor; identity alone never grants access.	A teammate's first login
ISO/IEC 27001 A.5.15 / A.8.5	Access control & secure authentication. Access is deny-by-default and granted per device, not per credential.	A teammate's first login
SOC 2 CC6.1	Logical access security. A new principal is denied at the gate until explicitly authorized.	A teammate's first login
DORA Art. 9(3)	Strong authentication mechanisms. Robust access control gates every new device before it reaches a system.	A teammate's first login

SOC 2 CC6.2 / CC6.3	Access provisioning. A new principal and device are granted access centrally, by an authorized admin, with a presence check.	Approve the person & trust the device
ISO/IEC 27001 A.5.16 / A.5.18	Identity & access-rights management. Enrolment of a user and device is an explicit, authorized, recorded act.	Approve the person & trust the device
NIS2 Art. 21(2)(j)	Secured access. Device trust is admitted only by an already-trusted admin, with out-of-band code confirmation.	Approve the person & trust the device
DORA Art. 9(4)	Access on a need-to-know basis. Access is conferred deliberately by an admin, not assumed from a login.	Approve the person & trust the device
SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. A device is admitted and, just as immediately, revocable centrally when lost or on a leaver.	Access granted
ISO/IEC 27001 A.5.15 / A.8.1	Access control & user-endpoint devices. Per-device trust is granted, badged and revoked from one place.	Access granted
NIS2 Art. 21(2)(j)	Secured access. Hardware-bound trust is admitted and revoked per device and per person.	Access granted
DORA Art. 9	Protection & prevention. Immediate device revocation contains a lost device or a departing insider.	Access granted
ISO/IEC 27001 A.8.6	Capacity management. Memory is reserved, budgeted and admission-controlled from live host state; over-use is detected and alerted.	Memory governance & the on-demand pool

SOC 2**A1.1**

Availability. Critical (always-on) workloads keep their reserved capacity; non-critical ones are shed under pressure without losing their state.

Memory**governance & the on-demand pool****NIS2****Art.
21(2)(c)**

Business continuity & capacity. Resource pressure is managed automatically so essential services stay available.

Memory**governance & the on-demand pool****DORA****Art. 9**

Performance & capacity. ICT resource limits are governed and monitored, with alerts when a workload exceeds its budget.

Memory**governance & the on-demand pool**

TECHNICAL-CONTROLS GUIDE

What Bailey gives you — at a glance

For each standard, how many technical controls Bailey provides outright, supports in part, or leaves to you to operate. The pages that follow break each down control-by-control, with a pointer to the chapter that shows it working.

ISO/IEC 27001:2022	12 PROVIDED	1 PARTIAL	0 YOUR PART
SOC 2 (Trust Services Criteria)	9 PROVIDED	0 PARTIAL	0 YOUR PART
DORA (Regulation (EU) 2022/2554)	7 PROVIDED	1 PARTIAL	0 YOUR PART
NIS2 (Directive (EU) 2022/2555)	6 PROVIDED	2 PARTIAL	0 YOUR PART
GDPR (Regulation (EU) 2016/679)	4 PROVIDED	1 PARTIAL	0 YOUR PART

✓ **Provided**

delivered by the platform

▸ **Partial**

platform supports it; you complete it

○ **Your part**

your organization operates it

TECHNICAL-CONTROLS GUIDE

ISO/IEC 27001:2022

Annex A technical controls. Bailey implements the platform-side controls below; the management-system controls (policies, risk assessment, HR, physical) remain yours.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
A.5.9	Inventory of assets	✓ Provided	Workspaces, endpoints and processes enumerated from live state	Asset classification policy	03 · 06
A.5.15 / A.8.5	Access control & secure authentication	✓ Provided	Device-trust gate + OIDC at the platform edge	Your IdP, joiner/leaver process	01 · 04
A.5.18	Access rights (least privilege, review)	✓ Provided	Operator / auditor / member roles, server-enforced	Periodic access reviews	19
A.8.8	Management of technical vulnerabilities	✓ Provided	Pre-deploy CVE scan + in-tree waivers	Triage & remediation SLAs	10 · 18
A.8.9	Configuration management	► Partial	bitswan.yaml as declarative source of truth	Baseline definition & review	11

A.8.13	Information backup	✓ Provided	Per-stage snapshots + retention policy	Offsite copy & retention targets	15
A.8.15 / A.8.16	Logging & monitoring	✓ Provided	Versioned deploy/event history, live container health, real-time SIEM export (OTLP)	SIEM correlation rules, alerting	12 · 14 · 21
A.8.20 / A.8.21	Network & network-services security	✓ Provided	Default-deny egress allow-list per service	Perimeter & internal segmentation policy	17
A.8.24	Use of cryptography & secrets	✓ Provided	Stage secrets, injected not committed; TLS at edge	Key-management policy	13
A.8.31	Separation of dev/test/production	✓ Provided	Isolated copies + dev / staging / production stages	—	05 · 09 · 11
A.8.3	Information access restriction	✓ Provided	Workspaces scope access per tenancy + role; per-endpoint owner-managed sharing	Membership reviews	02 · 20

A.8.32	Change management	✓ Provided	Reversible blue-green promotion path + immutable history	Change approval workflow	11 • 12
A.5.30	ICT readiness for business continuity	✓ Provided	DR slot + rehearsed, recorded recovery tests	BCP/DR plan & RTO/RPO targets	16

TECHNICAL-CONTROLS GUIDE

SOC 2 (Trust Services Criteria)

The common-criteria and availability TSCs Bailey supports as a service component. Your audit still covers the organizational criteria (CC1–CC5), risk assessment and vendor management.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
CC6.1	Logical access security	✓ Provided	Device-trust gate fronting every endpoint	Access policy & ownership	01 · 03
CC6.2 / CC6.3	Access provisioning & removal	✓ Provided	Central role + device grant/revoke	Timely de-provisioning process	04 · 19
CC6.6	Boundary protection	✓ Provided	Default-deny egress allow-list	Network perimeter design	17
CC6.7	Data in transit & at rest	✓ Provided	TLS at the edge (traefik) with managed cert lifecycle; backups encrypted	Disk encryption on the Bailey host (at rest)	01 · 15
CC7.1	Vulnerability detection	✓ Provided	SBOM + CVE scan on the image that ships	Remediation tracking	18

CC7.2	System monitoring	✓ Provided	Container health + event history + real-time SIEM export	Alerting & on-call	12 · 14 · 21
CC8.1	Change management	✓ Provided	Promotion pipeline + immutable deploy history	Change authorization	10 · 11 · 12
A1.2	Backup & environmental protection	✓ Provided	Snapshots + standby DR slot	Backup off-platform	15 · 16
A1.3	Recovery testing	✓ Provided	Rehearse-into-DR + recorded recovery tests	Test cadence sign-off	16

TECHNICAL-CONTROLS GUIDE

DORA (Regulation (EU) 2022/2554)

The ICT risk-management articles Bailey operationalizes for financial entities. Governance, incident reporting to authorities, and third-party registers remain your obligation.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 8	Identification of ICT risk	✓ Provided	Pre-deploy supply-chain / CVE identification	Risk register & classification	18
Art. 9(3)	Strong authentication & protection	✓ Provided	Device-trust gate	Identity governance	01
Art. 9	Protection & prevention (change impact)	✓ Provided	Zero-downtime blue-green change path	Segregation policy	11
Art. 10	Detection of anomalous activity	✓ Provided	Container health + deploy/event history + real-time SIEM export	Detection thresholds & alerting	12 · 14 · 21
Art. 11	Response & recovery	✓ Provided	One-cutover DR swap, no data move	Crisis-management plan	16
Art. 12	Backup, restoration & testing	✓ Provided	Snapshots + rehearsed DR restores	RTO/RPO & offsite policy	15 · 16

Art. 13	Learning & evolving	✓ Provided	Complete, inspectable deploy audit trail	Post-incident review process	12
Art. 24–26	Resilience testing programme	▸ Partial	Runnable requirement tests + DR rehearsals	TLPT for significant entities	08 · 16

TECHNICAL-CONTROLS GUIDE

NIS2 (Directive (EU) 2022/2555)

The Article 21(2) cybersecurity-risk-management measures Bailey delivers technically. Governance, training and incident notification to your CSIRT stay with you.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 21(2)(a)	Risk analysis & network security	▸ Partial	Default-deny egress with reviewed exceptions	Risk-analysis methodology	17
Art. 21(2)(b)	Incident handling	▸ Partial	Reconstruct events from the audit trail	Incident response & notification	12
Art. 21(2)(c)	Business continuity & backups	✓ Provided	Backups + zero-downtime DR swap	BCP & crisis comms	15 • 16
Art. 21(2)(d)	Supply-chain security	✓ Provided	SBOM + CVE visibility per image	Supplier assessment	18
Art. 21(2)(e)	Secure development & vuln handling	✓ Provided	Pre-deploy checks + versioned waivers	SDLC policy	10
Art. 21(2)(h)	Cryptography	✓ Provided	Secret handling + TLS at the edge	Crypto policy	13

Art. 21(2)(i)	Access control & asset management	✓ Provided	Roles + workspace/endpoint inventory + per-endpoint sharing	Asset ownership	02 · 03 · 19 · 20
Art. 21(2)(j)	Multi-factor authentication	✓ Provided	Hardware-bound device trust	Enrolment policy	01 · 04

TECHNICAL-CONTROLS GUIDE

GDPR (Regulation (EU) 2016/679)

The security-of-processing and accountability articles Bailey supports. Lawful basis, data-subject rights, DPIAs and breach notification remain controller obligations.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 30	Records of processing activities	✓ Provided	Per-egress data-processing record, auto-maintained	Controller-level register	17
Art. 28	Processor obligations / DPAs	✓ Provided	DPA stored before egress is allowed	Contract terms & due diligence	17
Art. 32	Security of processing	✓ Provided	Access control, secrets, backup & resilience	Risk-based measures & review	13 · 15 · 16
Art. 5(1)(f)	Integrity & confidentiality	✓ Provided	Gated access + default-deny egress	Data-handling policy	01 · 17
Art. 33	Breach notification	▸ Partial	Audit trail to reconstruct what happened	72-hour notification process	12

